CBUAE Classification: Public



ANTI-MONEY LAUNDERING AND COMBATING THE FINANCING OF TERRORISM AND ILLEGAL ORGANISATIONS

BEST PRACTICES FOR LICENSED FINANCIAL INSTITUTIONS ON IMPLEMENTING A RISK-BASED APPROACH AND CONDUCTING RISK-BASED INSTITUTIONAL RISK ASSESSMENTS

October, 2025

Contents

1. Introduction 3

1.1. Purpose and Scope 3

1.2. Applicability 4

1.3. Legal Basis 4

1.4. Acronyms 4

2. Implementing a Risk-Based Approach 5

2.1. Definition and Purpose 5

3. Conducting a Risk-Based Institutional Risk Assessment 6

3.1. Definition and Overview 6

3.1.1. Purpose of ML/TF/PF Risk Assessment 6
3.1.2. Overview of the characteristics of an effective risk assessment methodology 7
3.1.3. Granularity and level of detail in the risk assessment 8
3.1.4. Consultation, accountability and stakeholders relevant to the Risk Assessment 8
3.1.5. Frequency of the ML/TF/PF Risk Assessment 8

3.2. Principles and Best Practices for ML/TF/PF Institutional Risk Assessments 9

3.2.1. General Best Practices 9
3.2.2. Assessing Inherent Risk 10
15
3.2.3. Assessing the Control Environment 15
3.2.4. Determining Residual Risk 22

4. Application of an RBA 24

5. Conclusion 25

6. Annexure 1: Synopsis of the Best Practice 26

1. Introduction

To implement an effective anti-money laundering ("AML")/combating the financing of terrorism ("CFT")/ countering proliferation financing ("CPF") compliance program, a licensed financial institution ("LFI") should apply a risk-based approach ("RBA") to manage its money laundering ("ML"), terrorist financing ("TF"), proliferation financing ("PF"), and other illicit financial activity risk exposure. A reasonably designed RBA provides a framework for identifying the potential risks associated with an LFI's business model and activities, represented by the LFI's customers, products and services, delivery channels, geographic locations and markets, and operating structure. This understanding helps an LFI develop measures based on those risk factors that pose the greatest ML/TF/PF risk.

While the RBA is the overall framework and process that an LFI uses to manage ML/TF/PF risk, the ML/TF/PF risk assessment is a specific part of the RBA. A well-developed ML/TF/PF risk assessment assists LFIs in identifying ML, TF, PF, and other illicit financial activity risks. Based on this assessment of risk, an LFI is well-positioned to identify gaps or opportunities to further improve and develop appropriate risk mitigation measures—including an LFI's policies, procedures, processes, systems, and controls—in accordance with the nature and extent of the LFI's risk exposure.

1.1. Purpose and Scope

Article 44.11 of the *Cabinet Decision No. (10) of 2019 Concerning the Implementing Regulation of Decree Law No. (20) of 2018 on Anti-Money Laundering and Combating the Financing of Terrorism and Illegal Organisations* charges Supervisory Authorities with "providing Financial Institutions…with guidelines and feedback to enhance the effectiveness of implementation of the Crime-combatting measures."

The purpose of this Best Practices document is to **assist** the understanding and effective performance by the United Arab Emirates Central Bank's ("CBUAE") LFIs of their statutory obligations under the legal and regulatory framework in force in the UAE, of developing a risk assessment methodology, conducting a risk-based institutional risk assessment, and implementing a risk-based approach. It should be read in conjunction with the CBUAE's *Procedures for Anti-Money Laundering and Combating the Financing of Terrorism and Illicit Organizations* (issued by Notice No. 74/2019 dated 19/06/2019) and *Guidelines on Anti-Money Laundering and Combating the Financing of Terrorism and Illicit Organizations for Financial Institutions* (issued by Notice 79/2019 dated 27/06/2019) and any amendments or updates thereof.[1] As such, while this Best Practices document neither constitutes additional legislation or regulation nor replaces or supersedes any legal or regulatory requirements or statutory obligations, it sets out the **expectations** of the CBUAE for LFIs to be able to demonstrate compliance with these requirements. In the event of a discrepancy between this document and the legal or regulatory frameworks currently in force, the latter will prevail. This Best Practices document may be supplemented with additional separate guidance materials, such as outreach sessions and thematic reviews conducted by the CBUAE.

Furthermore, this Best Practices paper takes into account standards and guidance issued by the Financial Action Task Force ("FATF"), industry best practices and red flag indicators identified by the FATF. These are not exhaustive and do not set limitations on the measures to be taken by LFIs in order to meet their

[1] Available at https://www.centralbank.ae/en/cbuae-amlcft.

statutory obligations under the legal and regulatory framework currently in force. As such, LFIs should perform their own assessments of the manner in which they should meet their statutory obligations.

This Best Practices document comes into effect immediately upon its issuance by the CBUAE with LFIs expected to demonstrate compliance with its requirements within one month from its coming into effect.

1.2. Applicability

Unless otherwise noted, this Best Practices paper applies to all natural and legal persons, which are Financial Institutions or Licensees, or any other defined term which brings all entities within the scope of licensed and/or supervised entities by the CBUAE, in the following categories:

- National banks, branches of foreign banks, exchange houses, finance companies, stored value facilities, retail payment service providers, card schemes, virtual asset service providers ("VASPs"), registered hawala providers and other LFIs not explicitly mentioned; and
- Insurance and re-insurance companies, agents, and brokers.

1.3. Legal Basis

This Best Practices document builds upon the provisions of the following laws:

- Federal Decree Law No. 20 of 2018 on Anti-Money Laundering and Combating the Financing of Terrorism and Illegal Organizations as amended.
- Cabinet Decision No. (10) of 2019 concerning the Implementing Regulation of Federal Decree Law No. 20 of 2018 on Anti-Money Laundering and Combating the Financing of Terrorism and Illegal Organizations, as amended by Cabinet Decision 24 of 2022 ("AML-CFT Decision") and its amendments.
- Anti-Money Laundering and Combating the Financing of Terrorism and Illegal Organisations Guidelines for Financial Institutions of July 2023.

1.4. Acronyms

Terms	Description
AML	Anti-money laundering
CBUAE	Central Bank of the United Arab Emirates
CDD	Customer due diligence
CFT	Combating the financing of terrorism
CPF	Countering proliferation financing
EDD	Enhanced due diligence
FATF	Financial Action Task Force
KYC	Know your customer
LFI	Licensed financial institution

ML	Money laundering
MLRO	Money Laundering Reporting Officer
PEP	Politically exposed person
PF	Proliferation financing
RBA	Risk-based approach
SAR	Suspicious activity report
STR	Suspicious transaction report
TBML	Trade-based money laundering
TF	Terrorist financing
TFS	Targeted Financial Sanctions
VASP	Virtual Asset Service Provider

2. Implementing a Risk-Based Approach

2.1. Definition and Purpose

A Risk-based approach ("RBA") requires LFIs to identify, assess, and manage the ML/TF/PF risks to which they are exposed and subsequently apply AML/CFT/CPF measures commensurate with those risks in order to manage them effectively. A reasonably designed RBA will provide a framework for identifying the degree of potential ML/TF/PF risks associated with an LFI's customers, products and services, delivery channels, geographic locations and markets, and operating structure and enable an institution to focus on those risk factors that pose the greatest ML/TF/PF risk. As a general principle, where there are higher risks, LFIs should take enhanced measures to manage and mitigate those risks, while where the risks are lower, simplified measures (i.e., measures that still meet the core obligations and objectives of UAE laws and regulations but may involve less frequent monitoring or shallower levels of customer due diligence) may be permitted. The RBA thus allows LFIs, consistent with minimum legal and regulatory requirements, to adopt a more flexible set of measures in order to utilize their human, technological, and financial resources more effectively and apply AML/CFT/CPF preventive measures that are commensurate to the nature and level of their risks. As the purpose of the RBA is to allow an LFI to direct the most resources to the highest levels of assessed risk, LFIs should regularly review and update their frameworks to ensure that measures remain effective in managing ML/TF/PF risks.

Under the RBA, institutions that face higher ML/TF/PF risks are expected to develop enhanced measures to mitigate such higher risk by expanding the range, degree, frequency, and intensity of their mitigating controls. Conversely, institutions that face lower ML/TF/PF risks may choose to implement simplified measures, provided these are consistent with minimum legal and regulatory obligations.

As discussed in this Best Practices document, an RBA consists of the following steps:

- Conducting a risk-based institutional ML/TF/PF risk assessment (**Section 3**); and
- Applying an RBA (**Section 4**) in the implementation of AML/CFT/CPF controls, ensuring that the LFI's control environment appropriately manages the LFI's identified ML/TF/PF risks.

3. Conducting a Risk-Based Institutional Risk Assessment

3.1. Definition and Overview

As introduced in Section 2.1, an RBA consists of two essential elements: assessing risk and mitigating risk. The risk assessment enables an LFI to identify, assess, and understand the ML/TF/PF risks that may be present in the institution's business activities and clients. In order to do so, LFIs should periodically conduct a risk assessment that, at a minimum, takes into consideration the following:

- The LFI's customers and their characteristics;
- Products and services;
- Delivery channels and transaction-related risks;
- Geographic locations and markets; and

While the RBA is the overall framework and process used to manage ML/TF/PF risk, the conduct of the ML/TF/PF risk assessment is a specific part of the RBA. A risk assessment consists of identifying an institution's inherent ML/TF/PF risks based on the LFI's specific characteristics, business model, and activities; reviewing the design and operational effectiveness of an LFI's control framework to manage these risks; and determining the residual risk that remains after an LFI's controls are applied to its inherent risk. The results of the risk assessment are used to inform the development and implementation of the LFI's risk-based control framework and to continuously monitor and update this framework as necessary. An institutional risk assessment does not need to be complex, but following RBA principles, it should be commensurate with the nature and the size of the institution's operations.

For example, simpler risk assessments may be sufficient for smaller or less complex institutions that carry similar categories of customers or whose activities are circumscribed to a particular jurisdiction or service. Conversely, complex institutions, which service a diverse pool of clients, provide different types of services, or operate in several jurisdictions, will need to perform risk assessments that are sophisticated and aligned with the LFI's complexity. Simpler risk assessments for smaller or less complex LFIs may use more standardized risk matrices or checklists to evaluate risks, while larger institutions may feel the need to develop more detailed risk models and analyses to address more complex risks. For all LFIs, the integration of technologies such as data analytics and artificial intelligence may be considered as a way to possibly enhance the accuracy and efficiency of risk assessments.

3.1.1. Purpose of ML/TF/PF Risk Assessment

The main purpose of the ML/TF/PF risk assessment is to improve an institution's financial crime risk management by identifying the ML/TF/PF risks that an institution is facing, determining how these risks are mitigated by an institution's AML/CFT/CPF controls, and establishing the residual risks that remains for the institution. The results of the risk assessment can be used for a variety of purposes, such as:

- Identifying gaps or opportunities for improvement in AML/CFT/CPF policies, procedures, processes, systems, and other mitigating controls;

- Developing an accurate risk appetite statement that adequately reflects an institution's ML/TF/PF risk tolerance and allows it to implement effective controls and allocate resources on the basis of risk;
- Understanding how a business unit's AML/CFT/CPF compliance program aligns with its risk profile;
- Lowering an institution's residual risk exposure by developing effective risk mitigation strategies and/or reducing exposure to inherent risks that cannot be managed effectively;
- Ensuring senior management is informed of the institution's key risks, controls gaps, and remediation efforts;
- Enhancing regulatory compliance and reporting, ensuring that the institution meets all relevant AML/CFT/CPF requirements;
- Assisting senior management with strategic decisions in relation to customer exits and account restrictions; and
- Informing supervisors about key risks, control gaps, and remediation efforts across the institution.

3.1.2. Overview of the characteristics of an effective risk assessment methodology

To implement an effective ML/TF/PF risk assessment, an LFI should have a well-developed risk assessment methodology that documents all the steps of the risk assessment process and the rationale that supports the ML/TF/PF risk assessment, such as reasoning behind chosen risk factors, scoring criteria, and instances when the LFI has chosen to deviate from standard practices. Although there is no standard risk assessment methodology, the ML/TF/PF risk assessment methodology should describe the risk factors assessed, types of quantitative or qualitative data evaluated, stakeholders involved in the development and review of the risk assessment, criteria used to score, weightings applied to distinct risk factors or categories, and any scoring overrides applied. LFIs should consider integrating external sources of information, such as the UAE national risk assessment, sectoral risk assessments, industry reports, and feedback from supervisory authorities, to enhance the accuracy and relevance of the risk evaluation. LFIs should also consider defining and conducting their risk assessment by assessment units[2], if applicable, that can help the LFI assess ML/TF/PF risks specific to an LFI's particular business line, activity, or legal entity. This includes a commitment to continuous improvement, ensuring that the methodology is regularly reviewed and updated to reflect changes in risks, regulatory requirements, and technological advancements. As such, the methodology should outline the assessment units that are in scope and the process for assessing distinct risk factors, types of data, and weightings across the assessment units. Finally, LFIs should note that data and data analytics-based RBA methodologies should meet the definition of risk management models[3] and should be treated in accordance with the requirements set out in the CBUAE's model management standards.

[2] Assessment units refer to distinct segments of an LFI's operations that may be assessed separately, such as specific business lines, departments, or legal entities.

[3] https://www.centralbank.ae/media/0oaarr3a/model-management-standards-attach-to-notice-5052-2022.pdf

3.1.3. Granularity and level of detail in the risk assessment

LFIs have flexibility regarding how they organize their ML/TF/PF risk assessments. Depending on the size, entity type, and complexity of the specific institution, a risk assessment may be organized across business lines or legal entities (referred to as assessment units) that can be consolidated into an enterprise-level risk assessment. As much as is possible or practical, LFIs should consider adopting standardized methodologies across assessment units, while ensuring that assessment processes retain flexibility across disparate units to allow for a tailored assessment of risk. Accordingly, a larger LFI may implement a global ML/TF/PF risk assessment with multiple sub-enterprise-level assessment units represented by separate regional or country-level ML/TF/PF risk assessments. For larger LFIs in particular, it is crucial to ensure risk assessments are tailored to the specific business and that the data used is relevant to that business line and has been validated and run through assurance checks. Whatever approach is chosen, however, the results of these assessments should be aggregated into an enterprise-level assessment report of inherent risks, mitigating controls, and residual risks.

3.1.4. Consultation, accountability and stakeholders relevant to the Risk Assessment

The decision regarding who manages and owns the risk assessment process may be impacted by how the risk assessment is conducted (i.e., by business lines, country, or region), and the decision will be influenced by the structure, global footprint, and complexity of an LFI. With that understanding, the ML/TF/PF risk assessment process should be managed by the LFI's Money Laundering Reporting Officer ("MLRO")/Compliance Officer, in coordination with the appropriate risk management function, and owned by the LFI's Board of Directors, owners/partners/shareholders, and senior management who are responsible for overseeing the LFI's AML/CFT/CPF program and providing final approval. Additionally, while an MLRO/Compliance Officer or the dedicated Risk Officer conducts the assessment, it is crucial that the LFI engage first line of defense employees, particularly, business line heads, as they are best positioned to offer detailed insights on ML/TF/PF risks facing their respective business lines, include providing customer and transactional data for the risk assessment. Front line engagement is particularly important as the ownership of ML/TF/PF risks remains with the business, who are also responsible for implementing any actions resulting from the gaps or weaknesses identified by the risk assessment exercise.

3.1.5. Frequency of the ML/TF/PF Risk Assessment

An LFI's ML/TF/PF risk assessment should be updated, at a minimum, on an annual basis, and also in response to certain "trigger" events. Trigger events are associated with changes to the following areas impacting an LFI:

- LFI's organizational structure, business model, or strategy, such as due to mergers or acquisitions and expansion into new markets. This may also include global and regional events with a significant bearing on the LFI's activities.
- Activities stemming from the LFI's customer base; introduction of new products, services, or technologies; or the jurisdictions where the LFI operates.

- AML/CFT/CPF program, including updates to applicable AML/CFT/CPF laws and regulations and implementation of new AML/CFT/CPF controls.
- The UAE's National ML/TF/PF Risk Assessment and CBUAE's Sectoral ML/TF/PF Risk Assessment.

As such, an LFI should update its ML/TF/PF risk assessment in response to the abovementioned trigger events to ensure that the risk assessment remains an accurate reflection of the LFI's ML/TF/PF risks and control environment.

3.2. Principles and Best Practices for ML/TF/PF Institutional Risk Assessments

An institutional risk assessment consists of three core steps:

- **Inherent Risk:** an identification and assessment of the ML/TF/PF risks inherent to an LFI's business model and activities, including specific risks associated with an LFI's customers, products and services, delivery channels, geographies, and operating structure.
- **Assessing the Control Environment:** an assessment of the design and operational effectiveness of the policies, procedures, systems, and other controls in place to mitigate the LFI's inherent ML/TF/PF risks.
- **Residual Risk:** an assessment of the risk that remains after an LFI's controls are applied to its inherent risk.



3.2.1. General Best Practices

As noted above, the RBA approach allows LFIs some flexibility in designing and implementing a risk assessment methodology that is tailored to the size, entity type, and complexity of the specific institution. Recognizing that risk assessments will therefore vary in accordance with a given LFI's activities and risk profile, all LFIs should implement the following best practices associated with their ML/TF/PF institutional risk assessment:

- **Data quality:** LFIs should conduct thorough data quality and assurance checks on the data that is utilized for the risk assessment. To this end, LFIs should apply sound scientific methods or algorithms to address any missing or incorrect data. LFIs should also utilize feedback mechanisms to address any inconsistencies or issues observed across data sets. With that understanding, the risk assessment exercise is not the tool for LFIs to rectify and address such data quality issues.

- **Quantitative Calculations:** LFIs should use quantifiable metrics to inform the risk assessment exercise. Specifically, LFIs should establish criteria to measure the effectiveness of each AML/CFT/CPF control. This can involve setting measurable goals for each control with metrics that are quantifiable in nature, such as a reduction in the number of flagged transactions that require no further action (decrease in false positives). LFIs should collect metrics on how each control performs against the established criteria. Such metrics should be linked to an objective assessment regarding the performance of certain controls within the LFI and that are weighted in proportion to their significance to an LFI's overall AML/CFT/CPF program. Please refer to Section 3.2.3 for more information on how to use metrics to assess an LFI's control environment.
- **Workpapers:** LFIs should maintain a record of any workpapers or risk assessment tools utilized to collect data and calculate scores or ratings for the ML/TF/PF institutional risk assessment.
- **Report:** LFIs should prepare a finalized, enterprise-level ML/TF/PF institutional risk assessment report consisting of an assessment of ML/TF/PF inherent risks, mitigating controls, and residual risks, together with any supporting data, observations, and qualitative analysis. LFIs with multiple branches or business lines may maintain risk assessments for multiple sub-enterprise-level assessment units; however, the results of these assessments should be consolidated into an enterprise-level assessment of inherent risks, mitigating controls, and residual risks.
- **Policies and governance documentation:** LFIs should document their ML/TF/PF institutional risk assessment policies and governance structures and processes. Such documentation should clearly indicate required approvals for the risk assessment report and/or methodology, the required frequency for conducting risk assessments, and any follow-up actions the institution takes to address control weaknesses or areas of heighted residual risk identified by the risk assessment.
- **Third-party arrangements**: In cases where an LFI chooses to engage the services of a consultant, the LFI should ensure that the consultant delivers the contracted services under stringent oversight of key personnel nominated by the LFI and that such key personnel have a clear grasp of the services provided by the consultant. LFIs should avoid arrangements with consultants that result in an overreliance/dependency on such consultants. LFIs ultimately own the ML/TF/PF institutional risk assessment process and outcomes.

3.2.2. Assessing Inherent Risk

Global standards emphasize that effective risk management is predicated on a sound understanding of the risks inherent to an entity's business model. While there are different methods to conduct a risk assessment, LFIs are generally expected to evaluate, at a minimum, the differing levels of risk associated with their customers, products and services, delivery channels, geographic locations and markets, and operating structure, as appropriate. Depending on the nature, size, and complexity of their business, LFIs should also take into consideration other risk factors that might have a significant impact on the institution's exposure to ML/TF/PF risks. Some of the additional risk factors include, but not limited to, transaction-related risk (refer to CBUAE Notice 3599); relative size of the LFI's business; introduction of new products or services, new technologies or delivery processes; and the LFI's establishment of new branches and subsidiaries locally and abroad.

The following best practices can assist LFIs in effectively assessing their inherent risks, which is followed by a discussion of specific best practices for each core category of inherent risk.

- The risk assessment should consider high-risk factors and provide a reasonable rationale for situations where high-risk factors are not considered. For example, under the category of customer risk, an LFI may wish to consider the number of customers it has exited for financial crimes compliance ("FCC") reasons during the risk assessment review period and the number customers who have been the subject of a suspicious transaction report ("STR") or suspicious activity report ("SAR") during the risk assessment review period. If the number of customers exited for FCC reasons or STRs/SARs is not included in an LFI's risk assessment due to systems limitations, the risk assessment should note that the inherent risk rating is elevated due to the system limitation.
- The LFI should utilize a standardized approach to assessing its customers, products and services, geographies, and other factors, as applicable, and should, to the extent possible, utilize the same risk segments and risk rating methodologies in the institutional risk assessment as it utilizes as part of its day-to-day AML/CFT/CPF compliance program.
- Within each broad category of inherent risk (such as customer risk, product and service risk, geographies, etc.), the risk assessment should consider more granular risk factors for that category of inherent risk. Examples of granular risk factors for customer risk include a customer's place of residence or incorporation and primary place of business. Granular risk factors are addressed in Sections 3.2.2.1 to 3.2.2.5 under each broad category of inherent risk.
- The LFI should assign each factor a score or weighting that reflects the level of risk associated with that risk factor and the prevalence of that risk compared to other risk factors. Each risk area may then be assigned a weight that reflects the level of importance in the overall risk calculation relative to other risk areas. The risk score or weighting for each factor should be considered in the context of the collective risk assessed and measured by the LFI.
- The risk assessment should consider specific ML/TF/PF and other illicit financial activity risks associated with the LFI's business model and operating environment, including risks specific to the UAE, as identified in national and sectoral risk assessments and by international standard setters such as the FATF.
- While there is flexibility in the structure and flow of a risk assessment document, all LFIs should ensure that the assessment of risk factors includes quantitative data as a basis for evaluating and scoring each inherent risk category. The quantitative data should apply to the more granular risk factors for each category of inherent risk. For example, a higher weight could be assigned to factors like transaction volume or customer profile if they are deemed to have a greater impact on ML/TF/PF risk
- The risk assessment is a living document to be reviewed periodically and updated as the LFI prepares to add products or services, open locations in a new jurisdiction, or adopt a new piece of technology to serve its customers. An LFI's compliance department should insist upon a completed and approved risk assessment before an LFI adds a major new line of business.
- LFIs are encouraged to consider enhancing their risk assessments by utilizing the data submitted to the CBUAE for its annual institutional risk assessment.

3.2.2.1. Customers

An LFI's customer risk is based on the characteristics of its customer base, including the concentration of customers in risk-rated segments, customers' industries, professions, and entity type, and risk ratings of beneficial owners and other related parties, among other factors. The following are key drivers of inherent ML/TF/PF customer risk:

- Place of residence or incorporation and primary place of business;[4]
- Profession or industry, including but not limited to customers involved in financial services, real estate, export/import, or shipping, or those that are charities or other nonprofit organizations;
- Regulatory status (e.g., as a financial institution, virtual asset service provider ("VASP"), or designated non-financial business or profession ("DNFBP"));
- Business or other income-generating activities;
- Whether a customer is expected to transact with high-risk sectors, as defined by the LFI;
- Historical risk markers, such as being the subject of material negative news;
- Status as or exposure to politically exposed persons ("PEPs"), including through beneficial owners and other related parties;
- Corporate form and ownership structure; and
- Length of customer relationship.

3.2.2.2. Products and Services

Product and service risk derives from the range of products and services that an LFI offers its customers and whether those products and services have characteristics that present elevated illicit finance risk. The products and services a company offers are a key means by which illicit actors can exploit a company to introduce ill-gotten gains into the financial system, layer transactions to complicate any investigation into the source of funds or integrate illicit funds to make them appear legitimate. The following are key drivers of inherent ML/TF/PF product and service risk:

- Potential for intermediation (e.g., if an LFI acts as an intermediary in delivering the product or service, or the institution relies on a third party for information about a transacting party);
- Use of a higher-risk medium of exchange, such as cash, gold, or cryptocurrency;
- Use of products or services leveraging emerging technologies and financial innovations;
- Potential for anonymity or limited transparency;
- Cross-border flows of funds;
- Use of services that may enable pooling or obfuscation of funds, or in which multiple or anonymous parties can have authority over the disposition of funds;
- Favour complexity, especially when that complexity is excessive or unnecessary;

[4] LFIs may opt to address risks stemming from an LFI's exposure to customers resident, incorporated, or operating in higher-risk jurisdictions through their assessment of geographic risks, as discussed below.

- Involvement of multiple currencies or the conversion from one currency to another; and
- Near-instantaneous or irrevocable settlement or processing (also a driver of delivery channel risk).

3.2.2.3. Delivery Channels

Delivery channel risk stems from the extent to which an LFI's methods of account origination/customer onboarding, account servicing, and transaction facilitation limit its understanding of its customers' identities, activities, and counterparties. The following are key drivers of inherent ML/TF/PF delivery channel risk:

- Use of non-face-to-face channels;
- Proportion of unsolicited (e.g., walk-in) customers;
- Reliance on delivery by or through a third party; and
- Near-instantaneous or irrevocable settlement or processing (also a driver of product and service risk).

3.2.2.4. Geographies

Geographic risk stems from an LFI's exposure—through its operating locations (including those of any global affiliates and branches located outside of the UAE), customer base, and transactions—to regions and jurisdictions that present an elevated degree of illicit finance risk. The following are key drivers of inherent ML/TF/PF geographic risk:

- Institutional exposure (i.e., where the financial institution and its affiliates have locations and where it conducts business), including through proximity to higher-risk regions or jurisdiction in which the LFI may not directly operate; and
- Customer exposure (i.e., customers' country of citizenship or residence, locations of incorporation or registration, primary place or business/headquarters, locations of beneficial owners and related parties[5], and jurisdictions from which customers transact with the financial institution).[6]

[5] Related parties defined here as "Group and its Controlling Shareholders, Members of its Board and Senior Management, (and their First-Degree Relatives) and persons with control, joint control or significant influence over the Bank (and their First-Degree Relatives".
[6] LFIs may opt to address risks stemming from an LFI's exposure to customers resident, incorporated, or operating in higher-risk jurisdictions through their assessment of customer risks, as discussed below.

Measuring Inherent Risk

An LFI may choose to assess its inherent risk based on the likelihood that a ML/TF/PF risk event occurs and the impact should a ML/TF/PF risk event materialize, referred to as "risk scenarios."

- **Likelihood** is the potential for ML/TF/PF being present.
- **Impact** is the damage incurred if ML/TF/PF occurs.

To extent possible, the likelihood should be assessed on a relative scale and should be based on objective and/or quantifiable information. Subject matter expert inputs may be utilized to map likelihood scores to a rating category on a multi-scale system such as the following:

- **Very High:** Almost certain that a ML/TF/PF risk event will occur several times a year.
- **High**: High chance that a ML/TF/PF risk event will probably occur several times a year.
- **Moderate**: Moderate chance that a ML/TF/PF risk event will occur once a year.
- **Low**: Low chance but not impossible that a ML/TF/PF risk event will occur.
- **Incidental:** Relatively no chance that a ML/TF/PF risk event will occur.

Based on the risk factors discussed below in Section 3.2, certain risk factors contribute to lower or higher likelihood for ML/TF/PF risk. For example, customers in higher-risk professions or industries (as discussed in Section 3.2.2.1) will have a higher likelihood for ML/TF/PF risk. Furthermore, certain products and customer segments may pose a greater likelihood that an ML/TF/PF event will occur due to the value, volume, pattern of usage or the customer behavior associated with the products. Understanding likelihood, an LFI should then rate the impact if a ML/TF/PF event indeed occurs.

The impact can be assessed based on the possible regulatory, legal, financial, and reputational effects that could result if a ML/TF/PF event occurs. A five-level scale is provided as an example, but an LFI should adapt this scale to its business and activities.

- **Catastrophic**: The most severe damage (such as resulting in the loss of a license).
- **Major**: Significant damage.
- **Moderate:** Moderate level of damage.
- **Minor:** Minimal level of damage.
- **Incidental:** Little or no damage.

In this way, the LFI can determine the inherent risk rating of a risk factor. For example, the likelihood of an LFI's new CDD/KYC system or payment screening system suffering an extended outage may range from low to moderate depending on factors such as historical production incidents, existence of a data governance function and sophisticated application performance management capabilities etc.), but the impact that an outage would have on the LFI's operations is major. Please see the below matrix as an illustrative example for plotting likelihood and impact of a risk scenario to arrive at an LFI's inherent risk rating.

Measuring Inherent Risk (cont.)

Inherent Risk Rating as a Function of Likelihood and Impact

		Impact				
		Incidental - 1	Low - 2	Moderate - 3	Major - 4	Catastropic - 5
Likelihood	Very High - 5	Moderate - 5	High - 10	High - 15	Very High - 20	Very High - 25
	High - 4	Moderate - 4	Moderate - 8	High - 12	High - 16	Very High - 20
	Moderate - 3	Low - 3	Moderate - 6	Moderate - 9	High - 12	High - 15
	Low - 2	Very Low - 2	Low - 4	Moderate - 6	Moderate - 8	High - 10
	Very Low - 1	Very Low - 1	Very Low - 2	Low - 3	Moderate - 4	Moderate - 5

Risk Score

LFIs may adapt this inherent risk rating matrix for all types of customers, products and services, delivery channels and transactions, and geographies. For instance, a customer engaged in high-risk industries such as cryptocurrency trading might be rated as having a 'High' likelihood of ML/TF/PF risk, with an impact rating of 'Major' due to potential legal and reputational damage if involved in illicit activities.

3.2.3. Assessing the Control Environment

Once inherent risks have been identified and assessed, LFIs should assess mitigating controls to determine how effectively they manage the institution's risks. Mitigating controls include the LFI's policies, procedures, processes, systems, and other risk-mitigating measures, including overall governance and management oversight, customer due diligence ("CDD")/know your customer ("KYC"), internal controls (including suspicious transaction reporting and recordkeeping), training, and independent testing or independent audit. The following best practices can assist institutions in effectively assessing their mitigating controls, followed by specific best practices for each core controls category.

- To the extent possible, LFIs should map controls to specific drivers of inherent ML/TF/PF risk to ensure adequate coverage of mitigating controls, consistent with the RBA, and should assess controls both for appropriate design and for operational effectiveness.
- Each control area assessed should be assigned a score that reflects the relative strength of that control as well as a weighting based on the importance that the institution places on that control, given the institution's overall risk profile and risk appetite. The LFI should develop a table defining the scores used and the rationale applied when assigning a score to a given control's effectiveness.

- Where the LFI identifies a coverage gap in its existing control framework or determines that a specific control is not designed appropriately or operating effectively, the LFI should raise an action to remedy the deficiency if an action is not already underway.
- Control effectiveness assessments should be based on objective and quantifiable information tied to the controls. Examples of quantifiable factors include but are not limited to the following (the following is a non-exhaustive list of control effectiveness factors provided as examples. LFIs should develop detailed factors commensurate with their own customer, business and risk profiles):
    - The ratio of AML and sanctions related alerts flagged as deficient by independent quality assurance checks/assessments
    - The time taken to perform regulatory gap assessments and implementing the remedial measures identified by such assessments
    - The rolling rate of STR/SAR to total alert ratio and noteworthy alert to total alert ratio
    - The number of audit and compliance assurance issues and the time taken to address these issues
    - The rate of false positives in transaction monitoring systems
    - The ratio of low/medium risk rated customers that subsequently had STRs/SARs filed and/or high number of payments rejected by correspondent banks

3.2.3.1. Governance

An LFI's organizational structure and governance are key components to understanding and implementing AML/CFT/CPF controls and building an institution-wide culture of compliance. An LFI's organizational structure and governance should ensure that:

- Program documentation provides a clear framework for AML/CFT/CPF regulatory obligations—even through legal and regulatory changes or evolving compliance expectations and changes in compliance leadership—and is approved by the Board of Directors or an appropriate Board-level committee;
- The risk assessment process gives an LFI a baseline understanding of its risks and provides for the foundational framework for establishing a risk-based approach for both designing an AML/CFT/CPF compliance program and allocating resources to manage related risks;
- The compliance function is led by individuals with deep expertise in AML/CFT/CPF issues and the function has the appropriate authority and independence to manage AML/CFT/CPF risks, as established through clear reporting lines and communications ultimately up to the Board of Directors or a designated Board-level committee; and
- All levels of the institution understand and support the AML/CFT/CPF compliance mission through culture of compliance that is woven into the ordinary course of business, including through:
    - The responsibilities of the Board of Directors and/or designated Board-level committee(s) are explicitly discussed;

- The clear support and commitment of senior and mid-level management that sets a "tone from the top" in support of compliance objectives;
- Adequate human, technological, and financial resources to execute on compliance-related responsibilities; and
- Effective communication, incentives, and consequence management that together reinforce the culture of compliance.

Considerations to determine whether an LFI's governance controls are adequate and effective include:

- The LFI's risk appetite statement refers to ML/TF/PF risks and is subsequently integrated in the LFI's policies.
- The LFI performed an AML/CFT/CPF risk assessment that is documented, has been regularly updated, and evaluates the LFI's risk exposure across ML/TF/PF.
- The LFI has designated a MLRO/Compliance Officer who has his/her designation reported to CBUAE.
- The LFI operates across a three lines of defense model with roles that are appropriately segregated and enforced across the institution, such that the MLRO/Compliance Officer and the Compliance function are independent from business and first line activities.
- The MLRO/Compliance Officer reports directly to the Board of Directors, Board-designated committee, or owners/partners/shareholders.
- The LFI has developed an appropriate plan to address findings from any external compliance reviewer and a way to track the status of the remediation.
- Policies and procedures are updated and approved in a timely fashion and by the correct authority within the LFI.

3.2.3.2. CDD/KYC

Mitigating measures related to CDD/KYC are a key element of AML/CFT/CPF risk management, providing vital information about each customer. A robust CDD/KYC program establishes the LFI's understanding of risks associated with each customer as well as each customer's expected activity, better enabling the institution to detect unusual or potentially suspicious transactions. Effective CDD/KYC programs allow LFIs to segment customers by risk, apply appropriate Enhanced Due Diligence ("EDD") measures to customers designated as posing elevated levels of risk, and to give management a thorough understanding of the institution's customer base.

An effective CDD/KYC program has four essential elements:

- Customer identification and verification;
- Beneficial ownership identification and verification;
- Understanding the nature and purpose of customer relationships (including the identification of potential politically exposed persons ("PEPs") to develop a customer risk profile; and

- Ongoing monitoring for reporting suspicious transactions and, on a risk-basis, maintaining and updating customer information.

In addition to baseline CDD/KYC requirements that apply to all customers, LFIs are expected to apply specific and enhanced due diligence ("EDD") measures on the basis of a given customer's risk profile, as assessed at onboarding and on an ongoing basis thereafter.

Considerations to determine whether an LFI's CDD/KYC controls are adequate and effective include:

- The LFI has a clear client acceptance policy, and it is followed.
- The LFI undertakes adequate CDD/KYC for individual customers and legal entity customers.
- The LFI undertakes the appropriate measures to understand the customer's ownership and control structure and identify and verify the identity of the customer's beneficial owners.
- The LFI has appropriate measures to understand the purpose of the business relationship and nature of a customer's business.
- The LFI applies CDD/KYC measures not just prior to beginning any business relationships but on an ongoing basis, where appropriate.
- The LFI has a proper process to screen customers at onboarding and on an ongoing basis for sanctions and adverse media.
- The LFI undertakes adequate specialize due diligence and EDD for high-risk customers (such as for PEPs, correspondent banking relationships, etc.).

3.2.3.3. Internal Controls

Mitigating measures related to internal controls entail policies, procedures, and processes designed to limit and control risks associated with core operational elements of the LFI's AML/CFT/CPF program and achieve compliance with relevant laws and regulations. In addition to policies and procedures, effective internal controls also encompass technological systems that an LFI uses to identify, assess, and manage compliance risks, including the LFI's approach to suspicious activity monitoring, investigation, and reporting; other reporting and information sharing; recordkeeping and record retention; and risk assessment.

- The suspicious activity monitoring program helps the LFI validate its risk assessment on a client-by-client and institution-wide basis to inform the suspicious activity reporting program;
- Suspicious activity reports and information sharing provide valuable leads to law enforcement agencies and help shape investigative priorities and inform prosecutions; and
- The recordkeeping and record retention obligations require documentation and trail of information to evidence the investigation conducted by LFIs which led to the regulatory reporting. LFIs should evaluate whether records are complete, accurate, and readily accessible for the required retention period. This includes checking that records support the investigation and reporting of suspicious activities and are compliant with regulatory requirements.

Overall, the policies, procedures, and processes that comprise the LFI's system of internal controls also have implications for the institution's organizational structure, including staff to ensure appropriate allocation of resources to appropriately address risks and ensure effective implementation of controls. In addition to baseline internal controls that apply to all operations, LFIs are expected to apply specific and enhanced monitoring to higher-risk areas.

Considerations to determine whether an LFI's internal controls are adequate and effective include:

- The LFI maintains consistent and complete customer data in relevant systems and has a sufficient alert workflow to manage and close/escalate the alerts.
- The LFI monitors all business relationships (including employee accounts) on an adequate basis with a monitoring system/process that is up to date and adequately designed to detect ML/TF/PF transactions and activity in line with the LFI's ML/TF/PF risk assessment and business.
- The LFI has an adequate process in place to report suspicious transactions and activity to the Financial Intelligence Unit and to decide whether an investigated account should be maintained, closed or subject to further monitoring.
- The LFI effectively implements its sanctions screening regime in accordance with regulatory requirements, such that the sanctions screening regime is configured to detect and manage the specific sanctions risks to which the LFI is exposed and is calibrated to the size, nature, and complexity of the LFI.
- The LFI implements Targeted Financial Sanctions ("TFS") during: (i) alert screening at customer onboarding and throughout the business relationship; and (ii) payment screening.
- The LFI maintains all customer records such that transactions recorded in the customer's account can evidence the investigation conducted by LFIs which led to the regulatory reporting.

3.2.3.4. Training

Global standards consistently emphasize the need for an enterprise-wide AML/CFT/CPF training program for all appropriate personnel within an LFI. Comprehensive mitigating measures related to training are critical to the overall effectiveness of an AML/CFT/CPF compliance program. Training should be provided on an ongoing basis and include changes to regulations, internal policies or procedures, and an understanding of evolving AML/CFT/CPF risks to which the LFI is exposed.

At a minimum, a comprehensive AML/CFT/CPF training program should ensure that:

- All new employees receive the LFI's required AML/CFT/CPF training within a specified time from their onboarding date;
- All staff within an LFI receive AML/CFT/CPF awareness training at least annually;
- The LFI provides targeted and role-based training to employees in the relevant compliance functions;
- The LFI provides targeted and role-based training to front-line staff with heightened exposure to AML/CFT/CPF risk;
- The LFI provides AML/CFT/CPF training an ongoing basis to the third line of defense; and

- The LFI provides AML/CFT/CPF training to the LFI's board of directors and senior management.

Considerations to determine whether an LFI's training controls are adequate and effective include:

- The LFI provides compulsory AML/CFT/CPF induction training and ongoing refresher AML/CFT/CPF training to all staff, including the Board of Directors and senior management;
- The LFI provides certain specialized and role-based training programs for relevant staff with AML/CFT/CPF responsibilities (e.g., TBML and PF awareness training for teams facilitating trade-finance).
- The LFI maintains training attendance and assessment records, and follows up on employees who repeatedly do not attend or fail trainings
- AML/CFT/CPF trainings are customized to the LFI's risk and the nature of its operations, including local regulatory requirements.

3.2.3.5. Independent Testing

Independent Testing is a risk-based, objective evaluation of the overall strength and quality of an LFI's AML/CFT/CPF program. Testing includes reviewing the LFI's policies, procedures, systems, and controls that mitigate and manage an LFI's ML/TF/PF risks and identifying any areas of the compliance program that may require remediation or improvement. Best practices suggest periodic testing of the AML/CFT/CPF program every 12-18 months or in light of significant changes to the LFI's risk profile, policies, procedures, systems, controls, or compliance staff. Although many LFIs have internal audit departments that execute independent testing, outside auditors, consultants, or other qualified independent parties can also conduct independent testing and/or audits.

Institutions should take steps to ensure the autonomy of the independent testing function by separating the resources dedicated to testing from those that create the policies, procedures, systems, and controls subject to testing. For LFIs that use external auditors or consultants for independent testing, the audit/independent testing program should ensure that there is no conflict of interest between the external auditors and the LFI. Conflicts of interest may include external auditors providing additional services such as training or helping the LFI develop and implement its compliance policies, procedures, systems, and controls.

At a minimum, a comprehensive audit/independent testing program should assess:

- The overall integrity and effectiveness of the institution's AML/CFT/CPF program, including policies, procedures, and processes;
- The LFI's risk assessment for reasonableness given the LFI's risk profile;
- The LFI's adherence to global standards regarding identifying, investigating, and reporting different types of suspicious transactions and maintaining relevant records;
- Management's efforts to resolve violations and deficiencies identified in previously conducted independent testing and audit reports; and

- The integrity and accuracy of the LFI's information technology systems and automated programs used to identify suspicious transactions and possible sanctions hits to satisfy AML/CFT/CPF compliance requirements.

The findings identified in the independent testing of the AML/CFT/CPF program should be promptly provided to the LFI's Board of Directors or owners/partners/shareholders in a comprehensive audit report. The audit report should contain the methodology of the independent testing and mention any violations; inconsistencies between policy, procedures, and processes and the way they are applied; and any other program deficiencies found during the assessment. Most importantly, the comprehensive report should assist the LFI's Board of Directors, owners/partners/shareholders, and senior management in identifying, prioritizing, implementing, and tracking corrective actions meant to address these deficiencies.

Considerations to determine whether an LFI's independent testing controls are adequate and effective include:

- The LFI has established an effective audit function which is independent of all operations.
- The audit function is appropriately staffed and organised.
- The audit function has the requisite competencies and experience to carry out its responsibilities effectively, commensurate with the LFI's ML/TF/PF risks.
- The audit function performs periodic inspections, and testing covers all aspects of the LFI's AML/CFT/CPF compliance program, which is supported with a comprehensive methodology and testing plan.
- The LFI's audit plan and audit report have been approved by the LFI's Board of Directors, Board-designated committee, or owners/partners/shareholders.

Quantifying Control Effectiveness

To quantify control effectiveness, an LFI should consider applying the following steps:

1. **Identify Key Controls**: LFIs should list all relevant controls that have been implemented to mitigate identified risks. These controls may include CDD/KYC procedures, transaction monitoring systems, employee training programs, and compliance auditing mechanisms.

2. **Define Effectiveness Criteria**: LFIs should establish criteria to measure the effectiveness of each control. This can involve setting specific, measurable goals for each control, such as reduction in the number of flagged transactions that require no further action (decrease in false positives), or the speed and accuracy of identifying high-risk transactions or clients.

3. **Measure Performance Against Criteria**: LFIs should collect data on how each control performs against the established criteria. This can involve quantitative measures such as the number of STRs/SARs filed, the rate of compliance with CDD/KYC requirements, or qualitative assessments through internal audits and external reviews.

4. **Scoring System for Controls**: LFIs should develop a scoring system to rate the effectiveness of each control based on its performance. For example, you might score controls on a scale from 1 (ineffective) to 5 (highly effective) based on how well they meet the effectiveness criteria.

5. **Aggregate Control Scores**: LFIs should calculate an overall control effectiveness score by aggregating the scores of individual controls. This can be done through a weighted average if certain controls are deemed more critical than others based on your institution's risk profile.

6. **Adjust for Interdependencies**: LFIs should recognize that controls might be interdependent. The effectiveness of one control might enhance or depend on the effectiveness of another. Consider these relationships when evaluating overall effectiveness.

7. **Feedback and Improvement Cycle**: LFIs should use the results from the quantification exercise to identify areas where controls could be improved. LFIs should then implement feedback loops where control effectiveness data is regularly reviewed and used to adjust control mechanisms.

8. **Regular Updates and Reviews**: Control effectiveness should be an ongoing concern, with regular updates and reviews, to ensure that controls are adapting to evolving risks, regulatory changes, and operational requirements.

9. **Documentation and Reporting**: LFIs should keep detailed records of the evaluation process, results, and any subsequent actions taken to improve control effectiveness.

3.2.4. Determining Residual Risk

3.2.4.1. Approach

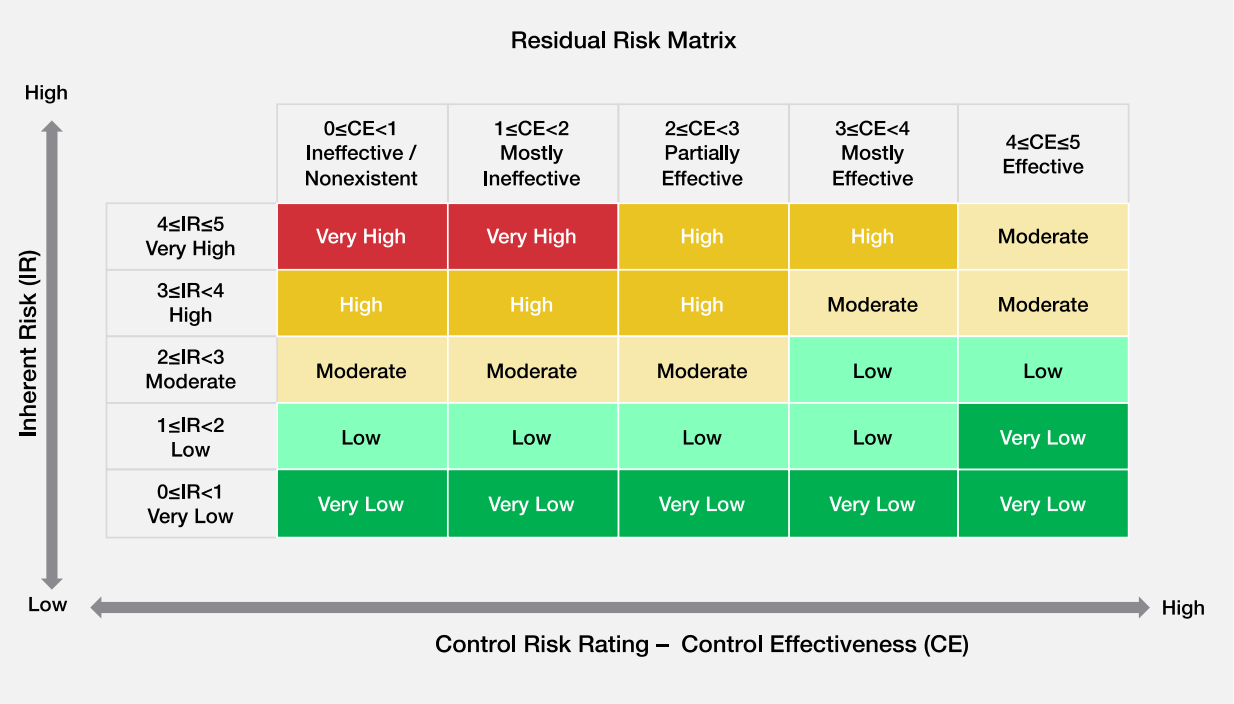
Once both the inherent risk and the design and effectiveness of an entity's mitigating controls have been considered, risk assessments should determine the entity's overall residual risk. Overall enterprise-wide residual risk is a function of the total inherent risk to which the LFI is exposed—through the customers,

geographies, products, services, delivery channels, transactions, and operational factors—and the extent to which its controls effectiveness limits the real risk that the inherent exposure will cause harm.

Determining residual risk is important to identify the nature and extent of ML/TF/PF risks so that an LFI's AML/CFT program can include tailored and effective risk mitigating measures, dedicating additional human, technological, and financial resources to the areas of the entity's highest risk. To that end, the outputs and findings of an LFI's risk assessment should be reasonable, and wherever the results are different than expected, these discrepancies should be rationally explained. LFIs should also retain previous versions of risk assessments to quickly and succinctly demonstrate to regulators or third-party assessors how the LFI's risk environment, related mitigating controls/measures, and residual risk have evolved over time. Senior management and the Board of Directors or owners/partners/shareholders can also reference previous versions when considering the LFI's risk appetite.

3.2.4.2. Residual Risk Matrix

A common practice for determining overall residual risk is the utilization of a residual risk matrix that aligns inherent risk and mitigating controls ratings or scores to generate a residual risk rating or score along a standardized assessment scale. Below is a sample residual risk matrix that utilizes a five-level scale for assessing inherent risks, mitigating controls, and the resulting residual risks. The below graphic is one example of a matrix that an LFI could leverage, and it is not meant to be mandatory or definitive. If an LFI, in the process of conducting its risk assessment, concludes a different risk rating matrix is more suited to its operating environment, an LFI should develop a risk rating matrix, which meets the minimum regulatory standards. The process for developing the risk rating matrix and rationale behind such a process should be clearly and thoroughly documented in an LFI's risk assessment methodology.



4. Application of an RBA

Once the LFI has identified and assessed the ML/TF/PF risks it faces, an LFI's Board of Directors, owners/partners/shareholders, or senior management should revisit the LFI's risk appetite statement to ensure it adequately reflects an institution's ML/TF/PF risk. The LFI's Board of Directors, owners/partners/shareholders or senior management should also assess whether they would like to lower the LFI's residual risk exposure by developing or updating AML/CFT/CPF controls and/or reducing exposure to inherent risks that cannot be managed effectively.

Based on this understanding, the LFI should develop a detailed action plan for the Board of Directors or owners/partners/shareholders that outlines new or updated AML/CFT/CPF controls for addressing inherent risks identified in the ML/TF/PF risk assessment and includes an estimated timeline of implementation. This action plan should take into account an RBA, such that if an LFI's residual risk increases, for instance, revealing that an LFI faces higher ML/TF/PF risks, the LFI may seek to develop enhanced measures to mitigate such higher risk by expanding the range, degree, frequency, and intensity of its AML/CFT/CPF controls. If possible, LFIs should consider leveraging advanced technology and data analytics to enhance its controls and measures. LFIs should clearly define the roles and responsibilities of different parts of the business in developing and executing changes to AML/CFT/CPF controls. Development and execution of changes to an LFI's AML/CFT/CPF controls may be tasked to different parts of an LFI's business, but the MLRO/Compliance Officer should maintain oversight and undertake coordination of these efforts. LFIs should prioritize controls and measures implementation based on where the assessment identified program gaps and deficiencies with increased levels of residual risk.

In accordance with an RBA, LFIs should mitigate identified risks through the implementation and updating of controls and measures tailored to these risks, such as:

- CDD/KYC processes, including customer and beneficial ownership identification and verification and developing an understanding the nature and intended purpose of the business relationship to establish a customer risk profile;
- EDD measures in higher-risk scenarios to obtain additional information on the customer and ensure enhanced ongoing monitoring and oversight of the customer relationship;
- Ongoing CDD monitoring to maintain current, accurate, and complete customer information and identify changes to the customer risk profile, which includes a risk-based frequency of sanctions and negative news screening of customers as well as routine transaction monitoring to develop averages of values/volumes transacted;
- Transaction monitoring controls and measures that detect and alert the LFI when customers have transactions based on the size, frequency, or patterns that may indicate unusual or potentially suspicious activity as well as activity that may be inconsistent with a customer's risk profile and/or history;
- Sanctions screening controls and measures for screening customers and transactions against relevant lists (e.g., the UN Consolidated List and the Local Terrorist Lists), reviewing potential sanctions matches, and escalating and reporting true sanctions hits;

- Suspicious activity monitoring systems and processes that are aligned to the institution's ML/TF/PF risk assessment and tailored to individual customer risk profiles, together with effective processes for reporting suspicious transactions or activity;
- Appropriate governance arrangements under which responsibility for AML/CFT/CPF is clearly allocated and senior leadership is closely involved in developing and implementing the RBA across the institution;
- Processes to recruit and vet staff in line with the institution's level and type of ML/TF/PF risk, to incentivize the advancement of compliance objectives, and to monitor the integrity of staff;
- Ongoing and role-based training for AML/CFT/CPF staff on the institution's business activities, risks, regulatory obligations, and policies and procedures;
- Controls to test the overall effectiveness of the institution's AML/CFT/CPF policies, procedures, and processes, including independent testing or auditing of the design and implementation of the institution's AML/CFT framework.

An effective RBA will help LFIs to address emerging risks and potential gaps or weaknesses in the AML/CFT/CPF framework that can be mitigated by introducing additional risk mitigation controls (new IT systems, supplemental job aids and desktop procedures, additional ML/TF/PF trainings on a particular topics, etc.), deploying additional resources (such as resources to support with CDD/KYC backlogs and late regulatory filings), and/or reducing exposure to inherent risks that cannot be managed effectively, as appropriate.

5. Conclusion

An ML/TF/PF risk assessment provides a snapshot of an LFI's ML/TF/PF risks and highlights gaps or weaknesses in an LFI's AML/CFT/CPF control environment. It is important that risk assessment findings are shared with an LFI's business lines, senior management, and Board of Directors, Board-designated committee, or owners/partners/shareholders, including other relevant stakeholders involved in the risk assessment process. Such stakeholders should be informed about the LFI's residual risk and on whether the risk assessment findings have changed or remained the same. Additionally, LFIs may wish to conduct a comparative analysis between the most recently conducted risk assessment and the one that preceded it, in order to keep a record of how the LFI has addressed it's AML/CFT/CPF program gaps and deficiencies over time.

Once an LFI has updated AML/CFT/CPF controls and based on the findings of the ML/TF/PF risk assessment, the LFI should review and test any new or revised controls. Such testing—whether conducted internally or by an independent third party—should be completed before the LFI's next risk assessment in order for the LFI to properly assess whether gaps from the risk assessment are addressed and aligned with the LFI's risk appetite. Findings from an LFI's risk assessment will also inform an LFI's business strategy, spanning customer exit decisions, monitoring and testing plans, and management information system data collected across an LFI. As such, LFIs should implement a robust ML/TF/PF risk assessment and pay particular attention to high-risk areas identified in the ML/TF/PF risk assessment in order to target the LFI's human, technological, and financial resources more effectively.

6. Annexure 1: Synopsis of the Best Practice

Introduction	**Purpose and Scope of the Best Practices**	The purpose of this Best Practices document is to assist the understanding and effective performance by the United Arab Emirates Central Bank's ("CBUAE") LFIs of their statutory obligations under the legal and regulatory framework in force in the UAE, of developing a risk assessment methodology, conducting a risk-based institutional risk assessment, and implementing a risk-based approach.
	Applicability	This Best Practices applies to all natural and legal persons, which are Financial Institutions or Licensees, or any other defined term which brings all entities within the scope of licensed and/or supervised entities by the CBUAE, in the following categories: national banks, branches of foreign banks, exchange houses, finance companies, payment service providers, virtual asset service providers, registered hawala providers; and insurance and re-insurance companies, agencies, and brokers.
	Legal Basis	• Federal Decree Law No. 20 of 2018 on Anti-Money Laundering and Combating the Financing of Terrorism and Illegal Organizations as amended. • Cabinet Decision No. (10) of 2019 concerning the Implementing Regulation of Federal Decree Law No. 20 of 2018 on Anti-Money Laundering and Combating the Financing of Terrorism and Illegal Organizations, as amended by Cabinet Decision 24 of 2022 ("AML-CFT Decision") and its amendments. • Anti-Money Laundering and Combating the Financing of Terrorism and Illegal Organisations Guidelines for Financial Institutions of July 2023.
	Definitions and Acronyms	• Several frequently used terms and phrase are defined, and a list of acronyms used in the Best Practices is provided.

Conducting a Risk-Based Institutional Risk Assessment	**Definition and Overview**	• This section details that a risk assessment consists of identifying an institution's inherent ML/TF/PF risks based on the LFI's specific characteristics, business model, and activities; reviewing the design and operational effectiveness of an LFI's control framework to manage these risks; and determining the residual risk that remains after an LFI's controls are applied to its inherent risk. • A broad example is provided of what risk assessments may look like for smaller, less complex institutions versus larger, more complex institutions. • This section also provides several examples of how LFIs can leverage the results of a risk assessment (e.g., developing an accurate risk appetite statement). • This section describes the granularity expected in a risk assessment, the relevant stakeholders in the risk assessment, and the frequency with which LFIs should conduct risk assessments.
	Principles and Best Practices for ML/TF/PF Institutional Risk Assessments	• This section outlines the three steps of a risk assessment: Measuring Inherent Risk; Assessing the Control Environment; Assessing Residual Risk. • General best practices are discussed, such as data quality and documentation. • There is extensive discussion and examples of an LFI assessing the inherent risk related to its customers, products, services, delivery channels, and geographies. A stand-alone text box and graphic provide aids for LFIs in conceptualizing inherent risk measurement. • There is discussion of assessing control effectiveness as it relates to an LFI's five-pillar AML program, including what should be included in the program and what supervisors may look for in an adequate program. • Finally, the section provides guidance on the approach for assessing residual risk and a graphic to aid LFIs in quantitatively measuring residual risk.
Application of an RBA	**Application of an RBA**	• This section notes that once a risk assessment is complete, the board of directors/senior management should revisit the LFI's risk appetite statement to ensure it adequately reflects an institution's ML/TF/PF risk as well as if the LFI needs to develop or update AML/CFT/CPF controls as a result of the assessment. • Several examples of how controls and measures could be updated are provided. • This section also encourages an LFI to develop a detailed action plan for the implementation or update of AML/CFT/CPF controls and that the MLRO should own the plan.

CBUAE Classification: Public



ANTI-MONEY LAUNDERING AND COMBATING THE FINANCING OF TERRORISM AND ILLEGAL ORGANISATIONS

BEST PRACTICES FOR LICENSED FINANCIAL INSTITUTIONS ON IMPLEMENTING A RISK-BASED APPROACH AND CONDUCTING RISK-BASED INSTITUTIONAL RISK ASSESSMENTS

October, 2025

Contents

1. Introduction 3

1.1. Purpose and Scope 3

1.2. Applicability 4

1.3. Legal Basis 4

1.4. Acronyms 4

2. Implementing a Risk-Based Approach 5

2.1. Definition and Purpose 5

3. Conducting a Risk-Based Institutional Risk Assessment 6

3.1. Definition and Overview 6

3.1.1. Purpose of ML/TF/PF Risk Assessment 6
3.1.2. Overview of the characteristics of an effective risk assessment methodology 7
3.1.3. Granularity and level of detail in the risk assessment 8
3.1.4. Consultation, accountability and stakeholders relevant to the Risk Assessment 8
3.1.5. Frequency of the ML/TF/PF Risk Assessment 8

3.2. Principles and Best Practices for ML/TF/PF Institutional Risk Assessments 9

3.2.1. General Best Practices 9
3.2.2. Assessing Inherent Risk 10
15
3.2.3. Assessing the Control Environment 15
3.2.4. Determining Residual Risk 22

4. Application of an RBA 24

5. Conclusion 25

6. Annexure 1: Synopsis of the Best Practice 26

1. Introduction

To implement an effective anti-money laundering ("AML")/combating the financing of terrorism ("CFT")/ countering proliferation financing ("CPF") compliance program, a licensed financial institution ("LFI") should apply a risk-based approach ("RBA") to manage its money laundering ("ML"), terrorist financing ("TF"), proliferation financing ("PF"), and other illicit financial activity risk exposure. A reasonably designed RBA provides a framework for identifying the potential risks associated with an LFI's business model and activities, represented by the LFI's customers, products and services, delivery channels, geographic locations and markets, and operating structure. This understanding helps an LFI develop measures based on those risk factors that pose the greatest ML/TF/PF risk.

While the RBA is the overall framework and process that an LFI uses to manage ML/TF/PF risk, the ML/TF/PF risk assessment is a specific part of the RBA. A well-developed ML/TF/PF risk assessment assists LFIs in identifying ML, TF, PF, and other illicit financial activity risks. Based on this assessment of risk, an LFI is well-positioned to identify gaps or opportunities to further improve and develop appropriate risk mitigation measures—including an LFI's policies, procedures, processes, systems, and controls—in accordance with the nature and extent of the LFI's risk exposure.

1.1. Purpose and Scope

Article 44.11 of the *Cabinet Decision No. (10) of 2019 Concerning the Implementing Regulation of Decree Law No. (20) of 2018 on Anti-Money Laundering and Combating the Financing of Terrorism and Illegal Organisations* charges Supervisory Authorities with "providing Financial Institutions…with guidelines and feedback to enhance the effectiveness of implementation of the Crime-combatting measures."

The purpose of this Best Practices document is to **assist** the understanding and effective performance by the United Arab Emirates Central Bank's ("CBUAE") LFIs of their statutory obligations under the legal and regulatory framework in force in the UAE, of developing a risk assessment methodology, conducting a risk-based institutional risk assessment, and implementing a risk-based approach. It should be read in conjunction with the CBUAE's *Procedures for Anti-Money Laundering and Combating the Financing of Terrorism and Illicit Organizations* (issued by Notice No. 74/2019 dated 19/06/2019) and *Guidelines on Anti-Money Laundering and Combating the Financing of Terrorism and Illicit Organizations for Financial Institutions* (issued by Notice 79/2019 dated 27/06/2019) and any amendments or updates thereof.[1] As such, while this Best Practices document neither constitutes additional legislation or regulation nor replaces or supersedes any legal or regulatory requirements or statutory obligations, it sets out the **expectations** of the CBUAE for LFIs to be able to demonstrate compliance with these requirements. In the event of a discrepancy between this document and the legal or regulatory frameworks currently in force, the latter will prevail. This Best Practices document may be supplemented with additional separate guidance materials, such as outreach sessions and thematic reviews conducted by the CBUAE.

Furthermore, this Best Practices paper takes into account standards and guidance issued by the Financial Action Task Force ("FATF"), industry best practices and red flag indicators identified by the FATF. These are not exhaustive and do not set limitations on the measures to be taken by LFIs in order to meet their

[1] Available at https://www.centralbank.ae/en/cbuae-amlcft.

statutory obligations under the legal and regulatory framework currently in force. As such, LFIs should perform their own assessments of the manner in which they should meet their statutory obligations.

This Best Practices document comes into effect immediately upon its issuance by the CBUAE with LFIs expected to demonstrate compliance with its requirements within one month from its coming into effect.

1.2. Applicability

Unless otherwise noted, this Best Practices paper applies to all natural and legal persons, which are Financial Institutions or Licensees, or any other defined term which brings all entities within the scope of licensed and/or supervised entities by the CBUAE, in the following categories:

- National banks, branches of foreign banks, exchange houses, finance companies, stored value facilities, retail payment service providers, card schemes, virtual asset service providers ("VASPs"), registered hawala providers and other LFIs not explicitly mentioned; and
- Insurance and re-insurance companies, agents, and brokers.

1.3. Legal Basis

This Best Practices document builds upon the provisions of the following laws:

- Federal Decree Law No. 20 of 2018 on Anti-Money Laundering and Combating the Financing of Terrorism and Illegal Organizations as amended.
- Cabinet Decision No. (10) of 2019 concerning the Implementing Regulation of Federal Decree Law No. 20 of 2018 on Anti-Money Laundering and Combating the Financing of Terrorism and Illegal Organizations, as amended by Cabinet Decision 24 of 2022 ("AML-CFT Decision") and its amendments.
- Anti-Money Laundering and Combating the Financing of Terrorism and Illegal Organisations Guidelines for Financial Institutions of July 2023.

1.4. Acronyms

Terms	Description
AML	Anti-money laundering
CBUAE	Central Bank of the United Arab Emirates
CDD	Customer due diligence
CFT	Combating the financing of terrorism
CPF	Countering proliferation financing
EDD	Enhanced due diligence
FATF	Financial Action Task Force
KYC	Know your customer
LFI	Licensed financial institution

ML	Money laundering
MLRO	Money Laundering Reporting Officer
PEP	Politically exposed person
PF	Proliferation financing
RBA	Risk-based approach
SAR	Suspicious activity report
STR	Suspicious transaction report
TBML	Trade-based money laundering
TF	Terrorist financing
TFS	Targeted Financial Sanctions
VASP	Virtual Asset Service Provider

2. Implementing a Risk-Based Approach

2.1. Definition and Purpose

A Risk-based approach ("RBA") requires LFIs to identify, assess, and manage the ML/TF/PF risks to which they are exposed and subsequently apply AML/CFT/CPF measures commensurate with those risks in order to manage them effectively. A reasonably designed RBA will provide a framework for identifying the degree of potential ML/TF/PF risks associated with an LFI's customers, products and services, delivery channels, geographic locations and markets, and operating structure and enable an institution to focus on those risk factors that pose the greatest ML/TF/PF risk. As a general principle, where there are higher risks, LFIs should take enhanced measures to manage and mitigate those risks, while where the risks are lower, simplified measures (i.e., measures that still meet the core obligations and objectives of UAE laws and regulations but may involve less frequent monitoring or shallower levels of customer due diligence) may be permitted. The RBA thus allows LFIs, consistent with minimum legal and regulatory requirements, to adopt a more flexible set of measures in order to utilize their human, technological, and financial resources more effectively and apply AML/CFT/CPF preventive measures that are commensurate to the nature and level of their risks. As the purpose of the RBA is to allow an LFI to direct the most resources to the highest levels of assessed risk, LFIs should regularly review and update their frameworks to ensure that measures remain effective in managing ML/TF/PF risks.

Under the RBA, institutions that face higher ML/TF/PF risks are expected to develop enhanced measures to mitigate such higher risk by expanding the range, degree, frequency, and intensity of their mitigating controls. Conversely, institutions that face lower ML/TF/PF risks may choose to implement simplified measures, provided these are consistent with minimum legal and regulatory obligations.

As discussed in this Best Practices document, an RBA consists of the following steps:

- Conducting a risk-based institutional ML/TF/PF risk assessment (**Section 3**); and
- Applying an RBA (**Section 4**) in the implementation of AML/CFT/CPF controls, ensuring that the LFI's control environment appropriately manages the LFI's identified ML/TF/PF risks.

3. Conducting a Risk-Based Institutional Risk Assessment

3.1. Definition and Overview

As introduced in Section 2.1, an RBA consists of two essential elements: assessing risk and mitigating risk. The risk assessment enables an LFI to identify, assess, and understand the ML/TF/PF risks that may be present in the institution's business activities and clients. In order to do so, LFIs should periodically conduct a risk assessment that, at a minimum, takes into consideration the following:

- The LFI's customers and their characteristics;
- Products and services;
- Delivery channels and transaction-related risks;
- Geographic locations and markets; and

While the RBA is the overall framework and process used to manage ML/TF/PF risk, the conduct of the ML/TF/PF risk assessment is a specific part of the RBA. A risk assessment consists of identifying an institution's inherent ML/TF/PF risks based on the LFI's specific characteristics, business model, and activities; reviewing the design and operational effectiveness of an LFI's control framework to manage these risks; and determining the residual risk that remains after an LFI's controls are applied to its inherent risk. The results of the risk assessment are used to inform the development and implementation of the LFI's risk-based control framework and to continuously monitor and update this framework as necessary. An institutional risk assessment does not need to be complex, but following RBA principles, it should be commensurate with the nature and the size of the institution's operations.

For example, simpler risk assessments may be sufficient for smaller or less complex institutions that carry similar categories of customers or whose activities are circumscribed to a particular jurisdiction or service. Conversely, complex institutions, which service a diverse pool of clients, provide different types of services, or operate in several jurisdictions, will need to perform risk assessments that are sophisticated and aligned with the LFI's complexity. Simpler risk assessments for smaller or less complex LFIs may use more standardized risk matrices or checklists to evaluate risks, while larger institutions may feel the need to develop more detailed risk models and analyses to address more complex risks. For all LFIs, the integration of technologies such as data analytics and artificial intelligence may be considered as a way to possibly enhance the accuracy and efficiency of risk assessments.

3.1.1. Purpose of ML/TF/PF Risk Assessment

The main purpose of the ML/TF/PF risk assessment is to improve an institution's financial crime risk management by identifying the ML/TF/PF risks that an institution is facing, determining how these risks are mitigated by an institution's AML/CFT/CPF controls, and establishing the residual risks that remains for the institution. The results of the risk assessment can be used for a variety of purposes, such as:

- Identifying gaps or opportunities for improvement in AML/CFT/CPF policies, procedures, processes, systems, and other mitigating controls;

- Developing an accurate risk appetite statement that adequately reflects an institution's ML/TF/PF risk tolerance and allows it to implement effective controls and allocate resources on the basis of risk;
- Understanding how a business unit's AML/CFT/CPF compliance program aligns with its risk profile;
- Lowering an institution's residual risk exposure by developing effective risk mitigation strategies and/or reducing exposure to inherent risks that cannot be managed effectively;
- Ensuring senior management is informed of the institution's key risks, controls gaps, and remediation efforts;
- Enhancing regulatory compliance and reporting, ensuring that the institution meets all relevant AML/CFT/CPF requirements;
- Assisting senior management with strategic decisions in relation to customer exits and account restrictions; and
- Informing supervisors about key risks, control gaps, and remediation efforts across the institution.

3.1.2. Overview of the characteristics of an effective risk assessment methodology

To implement an effective ML/TF/PF risk assessment, an LFI should have a well-developed risk assessment methodology that documents all the steps of the risk assessment process and the rationale that supports the ML/TF/PF risk assessment, such as reasoning behind chosen risk factors, scoring criteria, and instances when the LFI has chosen to deviate from standard practices. Although there is no standard risk assessment methodology, the ML/TF/PF risk assessment methodology should describe the risk factors assessed, types of quantitative or qualitative data evaluated, stakeholders involved in the development and review of the risk assessment, criteria used to score, weightings applied to distinct risk factors or categories, and any scoring overrides applied. LFIs should consider integrating external sources of information, such as the UAE national risk assessment, sectoral risk assessments, industry reports, and feedback from supervisory authorities, to enhance the accuracy and relevance of the risk evaluation. LFIs should also consider defining and conducting their risk assessment by assessment units[2], if applicable, that can help the LFI assess ML/TF/PF risks specific to an LFI's particular business line, activity, or legal entity. This includes a commitment to continuous improvement, ensuring that the methodology is regularly reviewed and updated to reflect changes in risks, regulatory requirements, and technological advancements. As such, the methodology should outline the assessment units that are in scope and the process for assessing distinct risk factors, types of data, and weightings across the assessment units. Finally, LFIs should note that data and data analytics-based RBA methodologies should meet the definition of risk management models[3] and should be treated in accordance with the requirements set out in the CBUAE's model management standards.

[2] Assessment units refer to distinct segments of an LFI's operations that may be assessed separately, such as specific business lines, departments, or legal entities.

[3] https://www.centralbank.ae/media/0oaarr3a/model-management-standards-attach-to-notice-5052-2022.pdf

3.1.3. Granularity and level of detail in the risk assessment

LFIs have flexibility regarding how they organize their ML/TF/PF risk assessments. Depending on the size, entity type, and complexity of the specific institution, a risk assessment may be organized across business lines or legal entities (referred to as assessment units) that can be consolidated into an enterprise-level risk assessment. As much as is possible or practical, LFIs should consider adopting standardized methodologies across assessment units, while ensuring that assessment processes retain flexibility across disparate units to allow for a tailored assessment of risk. Accordingly, a larger LFI may implement a global ML/TF/PF risk assessment with multiple sub-enterprise-level assessment units represented by separate regional or country-level ML/TF/PF risk assessments. For larger LFIs in particular, it is crucial to ensure risk assessments are tailored to the specific business and that the data used is relevant to that business line and has been validated and run through assurance checks. Whatever approach is chosen, however, the results of these assessments should be aggregated into an enterprise-level assessment report of inherent risks, mitigating controls, and residual risks.

3.1.4. Consultation, accountability and stakeholders relevant to the Risk Assessment

The decision regarding who manages and owns the risk assessment process may be impacted by how the risk assessment is conducted (i.e., by business lines, country, or region), and the decision will be influenced by the structure, global footprint, and complexity of an LFI. With that understanding, the ML/TF/PF risk assessment process should be managed by the LFI's Money Laundering Reporting Officer ("MLRO")/Compliance Officer, in coordination with the appropriate risk management function, and owned by the LFI's Board of Directors, owners/partners/shareholders, and senior management who are responsible for overseeing the LFI's AML/CFT/CPF program and providing final approval. Additionally, while an MLRO/Compliance Officer or the dedicated Risk Officer conducts the assessment, it is crucial that the LFI engage first line of defense employees, particularly, business line heads, as they are best positioned to offer detailed insights on ML/TF/PF risks facing their respective business lines, include providing customer and transactional data for the risk assessment. Front line engagement is particularly important as the ownership of ML/TF/PF risks remains with the business, who are also responsible for implementing any actions resulting from the gaps or weaknesses identified by the risk assessment exercise.

3.1.5. Frequency of the ML/TF/PF Risk Assessment

An LFI's ML/TF/PF risk assessment should be updated, at a minimum, on an annual basis, and also in response to certain "trigger" events. Trigger events are associated with changes to the following areas impacting an LFI:

- LFI's organizational structure, business model, or strategy, such as due to mergers or acquisitions and expansion into new markets. This may also include global and regional events with a significant bearing on the LFI's activities.
- Activities stemming from the LFI's customer base; introduction of new products, services, or technologies; or the jurisdictions where the LFI operates.

- AML/CFT/CPF program, including updates to applicable AML/CFT/CPF laws and regulations and implementation of new AML/CFT/CPF controls.
- The UAE's National ML/TF/PF Risk Assessment and CBUAE's Sectoral ML/TF/PF Risk Assessment.

As such, an LFI should update its ML/TF/PF risk assessment in response to the abovementioned trigger events to ensure that the risk assessment remains an accurate reflection of the LFI's ML/TF/PF risks and control environment.

3.2. Principles and Best Practices for ML/TF/PF Institutional Risk Assessments

An institutional risk assessment consists of three core steps:

- **Inherent Risk:** an identification and assessment of the ML/TF/PF risks inherent to an LFI's business model and activities, including specific risks associated with an LFI's customers, products and services, delivery channels, geographies, and operating structure.
- **Assessing the Control Environment:** an assessment of the design and operational effectiveness of the policies, procedures, systems, and other controls in place to mitigate the LFI's inherent ML/TF/PF risks.
- **Residual Risk:** an assessment of the risk that remains after an LFI's controls are applied to its inherent risk.



3.2.1. General Best Practices

As noted above, the RBA approach allows LFIs some flexibility in designing and implementing a risk assessment methodology that is tailored to the size, entity type, and complexity of the specific institution. Recognizing that risk assessments will therefore vary in accordance with a given LFI's activities and risk profile, all LFIs should implement the following best practices associated with their ML/TF/PF institutional risk assessment:

- **Data quality:** LFIs should conduct thorough data quality and assurance checks on the data that is utilized for the risk assessment. To this end, LFIs should apply sound scientific methods or algorithms to address any missing or incorrect data. LFIs should also utilize feedback mechanisms to address any inconsistencies or issues observed across data sets. With that understanding, the risk assessment exercise is not the tool for LFIs to rectify and address such data quality issues.

- **Quantitative Calculations:** LFIs should use quantifiable metrics to inform the risk assessment exercise. Specifically, LFIs should establish criteria to measure the effectiveness of each AML/CFT/CPF control. This can involve setting measurable goals for each control with metrics that are quantifiable in nature, such as a reduction in the number of flagged transactions that require no further action (decrease in false positives). LFIs should collect metrics on how each control performs against the established criteria. Such metrics should be linked to an objective assessment regarding the performance of certain controls within the LFI and that are weighted in proportion to their significance to an LFI's overall AML/CFT/CPF program. Please refer to Section 3.2.3 for more information on how to use metrics to assess an LFI's control environment.
- **Workpapers:** LFIs should maintain a record of any workpapers or risk assessment tools utilized to collect data and calculate scores or ratings for the ML/TF/PF institutional risk assessment.
- **Report:** LFIs should prepare a finalized, enterprise-level ML/TF/PF institutional risk assessment report consisting of an assessment of ML/TF/PF inherent risks, mitigating controls, and residual risks, together with any supporting data, observations, and qualitative analysis. LFIs with multiple branches or business lines may maintain risk assessments for multiple sub-enterprise-level assessment units; however, the results of these assessments should be consolidated into an enterprise-level assessment of inherent risks, mitigating controls, and residual risks.
- **Policies and governance documentation:** LFIs should document their ML/TF/PF institutional risk assessment policies and governance structures and processes. Such documentation should clearly indicate required approvals for the risk assessment report and/or methodology, the required frequency for conducting risk assessments, and any follow-up actions the institution takes to address control weaknesses or areas of heighted residual risk identified by the risk assessment.
- **Third-party arrangements**: In cases where an LFI chooses to engage the services of a consultant, the LFI should ensure that the consultant delivers the contracted services under stringent oversight of key personnel nominated by the LFI and that such key personnel have a clear grasp of the services provided by the consultant. LFIs should avoid arrangements with consultants that result in an overreliance/dependency on such consultants. LFIs ultimately own the ML/TF/PF institutional risk assessment process and outcomes.

3.2.2. Assessing Inherent Risk

Global standards emphasize that effective risk management is predicated on a sound understanding of the risks inherent to an entity's business model. While there are different methods to conduct a risk assessment, LFIs are generally expected to evaluate, at a minimum, the differing levels of risk associated with their customers, products and services, delivery channels, geographic locations and markets, and operating structure, as appropriate. Depending on the nature, size, and complexity of their business, LFIs should also take into consideration other risk factors that might have a significant impact on the institution's exposure to ML/TF/PF risks. Some of the additional risk factors include, but not limited to, transaction-related risk (refer to CBUAE Notice 3599); relative size of the LFI's business; introduction of new products or services, new technologies or delivery processes; and the LFI's establishment of new branches and subsidiaries locally and abroad.

The following best practices can assist LFIs in effectively assessing their inherent risks, which is followed by a discussion of specific best practices for each core category of inherent risk.

- The risk assessment should consider high-risk factors and provide a reasonable rationale for situations where high-risk factors are not considered. For example, under the category of customer risk, an LFI may wish to consider the number of customers it has exited for financial crimes compliance ("FCC") reasons during the risk assessment review period and the number customers who have been the subject of a suspicious transaction report ("STR") or suspicious activity report ("SAR") during the risk assessment review period. If the number of customers exited for FCC reasons or STRs/SARs is not included in an LFI's risk assessment due to systems limitations, the risk assessment should note that the inherent risk rating is elevated due to the system limitation.
- The LFI should utilize a standardized approach to assessing its customers, products and services, geographies, and other factors, as applicable, and should, to the extent possible, utilize the same risk segments and risk rating methodologies in the institutional risk assessment as it utilizes as part of its day-to-day AML/CFT/CPF compliance program.
- Within each broad category of inherent risk (such as customer risk, product and service risk, geographies, etc.), the risk assessment should consider more granular risk factors for that category of inherent risk. Examples of granular risk factors for customer risk include a customer's place of residence or incorporation and primary place of business. Granular risk factors are addressed in Sections 3.2.2.1 to 3.2.2.5 under each broad category of inherent risk.
- The LFI should assign each factor a score or weighting that reflects the level of risk associated with that risk factor and the prevalence of that risk compared to other risk factors. Each risk area may then be assigned a weight that reflects the level of importance in the overall risk calculation relative to other risk areas. The risk score or weighting for each factor should be considered in the context of the collective risk assessed and measured by the LFI.
- The risk assessment should consider specific ML/TF/PF and other illicit financial activity risks associated with the LFI's business model and operating environment, including risks specific to the UAE, as identified in national and sectoral risk assessments and by international standard setters such as the FATF.
- While there is flexibility in the structure and flow of a risk assessment document, all LFIs should ensure that the assessment of risk factors includes quantitative data as a basis for evaluating and scoring each inherent risk category. The quantitative data should apply to the more granular risk factors for each category of inherent risk. For example, a higher weight could be assigned to factors like transaction volume or customer profile if they are deemed to have a greater impact on ML/TF/PF risk
- The risk assessment is a living document to be reviewed periodically and updated as the LFI prepares to add products or services, open locations in a new jurisdiction, or adopt a new piece of technology to serve its customers. An LFI's compliance department should insist upon a completed and approved risk assessment before an LFI adds a major new line of business.
- LFIs are encouraged to consider enhancing their risk assessments by utilizing the data submitted to the CBUAE for its annual institutional risk assessment.

3.2.2.1. Customers

An LFI's customer risk is based on the characteristics of its customer base, including the concentration of customers in risk-rated segments, customers' industries, professions, and entity type, and risk ratings of beneficial owners and other related parties, among other factors. The following are key drivers of inherent ML/TF/PF customer risk:

- Place of residence or incorporation and primary place of business;[4]
- Profession or industry, including but not limited to customers involved in financial services, real estate, export/import, or shipping, or those that are charities or other nonprofit organizations;
- Regulatory status (e.g., as a financial institution, virtual asset service provider ("VASP"), or designated non-financial business or profession ("DNFBP"));
- Business or other income-generating activities;
- Whether a customer is expected to transact with high-risk sectors, as defined by the LFI;
- Historical risk markers, such as being the subject of material negative news;
- Status as or exposure to politically exposed persons ("PEPs"), including through beneficial owners and other related parties;
- Corporate form and ownership structure; and
- Length of customer relationship.

3.2.2.2. Products and Services

Product and service risk derives from the range of products and services that an LFI offers its customers and whether those products and services have characteristics that present elevated illicit finance risk. The products and services a company offers are a key means by which illicit actors can exploit a company to introduce ill-gotten gains into the financial system, layer transactions to complicate any investigation into the source of funds or integrate illicit funds to make them appear legitimate. The following are key drivers of inherent ML/TF/PF product and service risk:

- Potential for intermediation (e.g., if an LFI acts as an intermediary in delivering the product or service, or the institution relies on a third party for information about a transacting party);
- Use of a higher-risk medium of exchange, such as cash, gold, or cryptocurrency;
- Use of products or services leveraging emerging technologies and financial innovations;
- Potential for anonymity or limited transparency;
- Cross-border flows of funds;
- Use of services that may enable pooling or obfuscation of funds, or in which multiple or anonymous parties can have authority over the disposition of funds;
- Favour complexity, especially when that complexity is excessive or unnecessary;

[4] LFIs may opt to address risks stemming from an LFI's exposure to customers resident, incorporated, or operating in higher-risk jurisdictions through their assessment of geographic risks, as discussed below.

- Involvement of multiple currencies or the conversion from one currency to another; and
- Near-instantaneous or irrevocable settlement or processing (also a driver of delivery channel risk).

3.2.2.3. Delivery Channels

Delivery channel risk stems from the extent to which an LFI's methods of account origination/customer onboarding, account servicing, and transaction facilitation limit its understanding of its customers' identities, activities, and counterparties. The following are key drivers of inherent ML/TF/PF delivery channel risk:

- Use of non-face-to-face channels;
- Proportion of unsolicited (e.g., walk-in) customers;
- Reliance on delivery by or through a third party; and
- Near-instantaneous or irrevocable settlement or processing (also a driver of product and service risk).

3.2.2.4. Geographies

Geographic risk stems from an LFI's exposure—through its operating locations (including those of any global affiliates and branches located outside of the UAE), customer base, and transactions—to regions and jurisdictions that present an elevated degree of illicit finance risk. The following are key drivers of inherent ML/TF/PF geographic risk:

- Institutional exposure (i.e., where the financial institution and its affiliates have locations and where it conducts business), including through proximity to higher-risk regions or jurisdiction in which the LFI may not directly operate; and
- Customer exposure (i.e., customers' country of citizenship or residence, locations of incorporation or registration, primary place or business/headquarters, locations of beneficial owners and related parties[5], and jurisdictions from which customers transact with the financial institution).[6]

[5] Related parties defined here as "Group and its Controlling Shareholders, Members of its Board and Senior Management, (and their First-Degree Relatives) and persons with control, joint control or significant influence over the Bank (and their First-Degree Relatives".
[6] LFIs may opt to address risks stemming from an LFI's exposure to customers resident, incorporated, or operating in higher-risk jurisdictions through their assessment of customer risks, as discussed below.

Measuring Inherent Risk

An LFI may choose to assess its inherent risk based on the likelihood that a ML/TF/PF risk event occurs and the impact should a ML/TF/PF risk event materialize, referred to as "risk scenarios."

- **Likelihood** is the potential for ML/TF/PF being present.
- **Impact** is the damage incurred if ML/TF/PF occurs.

To extent possible, the likelihood should be assessed on a relative scale and should be based on objective and/or quantifiable information. Subject matter expert inputs may be utilized to map likelihood scores to a rating category on a multi-scale system such as the following:

- **Very High:** Almost certain that a ML/TF/PF risk event will occur several times a year.
- **High**: High chance that a ML/TF/PF risk event will probably occur several times a year.
- **Moderate**: Moderate chance that a ML/TF/PF risk event will occur once a year.
- **Low**: Low chance but not impossible that a ML/TF/PF risk event will occur.
- **Incidental:** Relatively no chance that a ML/TF/PF risk event will occur.

Based on the risk factors discussed below in Section 3.2, certain risk factors contribute to lower or higher likelihood for ML/TF/PF risk. For example, customers in higher-risk professions or industries (as discussed in Section 3.2.2.1) will have a higher likelihood for ML/TF/PF risk. Furthermore, certain products and customer segments may pose a greater likelihood that an ML/TF/PF event will occur due to the value, volume, pattern of usage or the customer behavior associated with the products. Understanding likelihood, an LFI should then rate the impact if a ML/TF/PF event indeed occurs.

The impact can be assessed based on the possible regulatory, legal, financial, and reputational effects that could result if a ML/TF/PF event occurs. A five-level scale is provided as an example, but an LFI should adapt this scale to its business and activities.

- **Catastrophic**: The most severe damage (such as resulting in the loss of a license).
- **Major**: Significant damage.
- **Moderate:** Moderate level of damage.
- **Minor:** Minimal level of damage.
- **Incidental:** Little or no damage.

In this way, the LFI can determine the inherent risk rating of a risk factor. For example, the likelihood of an LFI's new CDD/KYC system or payment screening system suffering an extended outage may range from low to moderate depending on factors such as historical production incidents, existence of a data governance function and sophisticated application performance management capabilities etc.), but the impact that an outage would have on the LFI's operations is major. Please see the below matrix as an illustrative example for plotting likelihood and impact of a risk scenario to arrive at an LFI's inherent risk rating.

Measuring Inherent Risk (cont.)

Inherent Risk Rating as a Function of Likelihood and Impact

		Impact				
		Incidental - 1	Low - 2	Moderate - 3	Major - 4	Catastropic - 5
Likelihood	Very High - 5	**Moderate - 5**	**High - 10**	**High - 15**	**Very High - 20**	**Very High - 25**
	High - 4	**Moderate - 4**	**Moderate - 8**	**High - 12**	**High - 16**	**Very High - 20**
	Moderate - 3	**Low - 3**	**Moderate - 6**	**Moderate - 9**	**High - 12**	**High - 15**
	Low - 2	**Very Low - 2**	**Low - 4**	**Moderate - 6**	**Moderate - 8**	**High - 10**
	Very Low - 1	**Very Low - 1**	**Very Low - 2**	**Low - 3**	**Moderate - 4**	**Moderate - 5**

Risk Score

LFIs may adapt this inherent risk rating matrix for all types of customers, products and services, delivery channels and transactions, and geographies. For instance, a customer engaged in high-risk industries such as cryptocurrency trading might be rated as having a 'High' likelihood of ML/TF/PF risk, with an impact rating of 'Major' due to potential legal and reputational damage if involved in illicit activities.

3.2.3. Assessing the Control Environment

Once inherent risks have been identified and assessed, LFIs should assess mitigating controls to determine how effectively they manage the institution's risks. Mitigating controls include the LFI's policies, procedures, processes, systems, and other risk-mitigating measures, including overall governance and management oversight, customer due diligence ("CDD")/know your customer ("KYC"), internal controls (including suspicious transaction reporting and recordkeeping), training, and independent testing or independent audit. The following best practices can assist institutions in effectively assessing their mitigating controls, followed by specific best practices for each core controls category.

- To the extent possible, LFIs should map controls to specific drivers of inherent ML/TF/PF risk to ensure adequate coverage of mitigating controls, consistent with the RBA, and should assess controls both for appropriate design and for operational effectiveness.
- Each control area assessed should be assigned a score that reflects the relative strength of that control as well as a weighting based on the importance that the institution places on that control, given the institution's overall risk profile and risk appetite. The LFI should develop a table defining the scores used and the rationale applied when assigning a score to a given control's effectiveness.

- Where the LFI identifies a coverage gap in its existing control framework or determines that a specific control is not designed appropriately or operating effectively, the LFI should raise an action to remedy the deficiency if an action is not already underway.
- Control effectiveness assessments should be based on objective and quantifiable information tied to the controls. Examples of quantifiable factors include but are not limited to the following (the following is a non-exhaustive list of control effectiveness factors provided as examples. LFIs should develop detailed factors commensurate with their own customer, business and risk profiles):
    - The ratio of AML and sanctions related alerts flagged as deficient by independent quality assurance checks/assessments
    - The time taken to perform regulatory gap assessments and implementing the remedial measures identified by such assessments
    - The rolling rate of STR/SAR to total alert ratio and noteworthy alert to total alert ratio
    - The number of audit and compliance assurance issues and the time taken to address these issues
    - The rate of false positives in transaction monitoring systems
    - The ratio of low/medium risk rated customers that subsequently had STRs/SARs filed and/or high number of payments rejected by correspondent banks

3.2.3.1. Governance

An LFI's organizational structure and governance are key components to understanding and implementing AML/CFT/CPF controls and building an institution-wide culture of compliance. An LFI's organizational structure and governance should ensure that:

- Program documentation provides a clear framework for AML/CFT/CPF regulatory obligations—even through legal and regulatory changes or evolving compliance expectations and changes in compliance leadership—and is approved by the Board of Directors or an appropriate Board-level committee;
- The risk assessment process gives an LFI a baseline understanding of its risks and provides for the foundational framework for establishing a risk-based approach for both designing an AML/CFT/CPF compliance program and allocating resources to manage related risks;
- The compliance function is led by individuals with deep expertise in AML/CFT/CPF issues and the function has the appropriate authority and independence to manage AML/CFT/CPF risks, as established through clear reporting lines and communications ultimately up to the Board of Directors or a designated Board-level committee; and
- All levels of the institution understand and support the AML/CFT/CPF compliance mission through culture of compliance that is woven into the ordinary course of business, including through:
    - The responsibilities of the Board of Directors and/or designated Board-level committee(s) are explicitly discussed;

- The clear support and commitment of senior and mid-level management that sets a "tone from the top" in support of compliance objectives;
- Adequate human, technological, and financial resources to execute on compliance-related responsibilities; and
- Effective communication, incentives, and consequence management that together reinforce the culture of compliance.

Considerations to determine whether an LFI's governance controls are adequate and effective include:

- The LFI's risk appetite statement refers to ML/TF/PF risks and is subsequently integrated in the LFI's policies.
- The LFI performed an AML/CFT/CPF risk assessment that is documented, has been regularly updated, and evaluates the LFI's risk exposure across ML/TF/PF.
- The LFI has designated a MLRO/Compliance Officer who has his/her designation reported to CBUAE.
- The LFI operates across a three lines of defense model with roles that are appropriately segregated and enforced across the institution, such that the MLRO/Compliance Officer and the Compliance function are independent from business and first line activities.
- The MLRO/Compliance Officer reports directly to the Board of Directors, Board-designated committee, or owners/partners/shareholders.
- The LFI has developed an appropriate plan to address findings from any external compliance reviewer and a way to track the status of the remediation.
- Policies and procedures are updated and approved in a timely fashion and by the correct authority within the LFI.

3.2.3.2. CDD/KYC

Mitigating measures related to CDD/KYC are a key element of AML/CFT/CPF risk management, providing vital information about each customer. A robust CDD/KYC program establishes the LFI's understanding of risks associated with each customer as well as each customer's expected activity, better enabling the institution to detect unusual or potentially suspicious transactions. Effective CDD/KYC programs allow LFIs to segment customers by risk, apply appropriate Enhanced Due Diligence ("EDD") measures to customers designated as posing elevated levels of risk, and to give management a thorough understanding of the institution's customer base.

An effective CDD/KYC program has four essential elements:

- Customer identification and verification;
- Beneficial ownership identification and verification;
- Understanding the nature and purpose of customer relationships (including the identification of potential politically exposed persons ("PEPs") to develop a customer risk profile; and

- Ongoing monitoring for reporting suspicious transactions and, on a risk-basis, maintaining and updating customer information.

In addition to baseline CDD/KYC requirements that apply to all customers, LFIs are expected to apply specific and enhanced due diligence ("EDD") measures on the basis of a given customer's risk profile, as assessed at onboarding and on an ongoing basis thereafter.

Considerations to determine whether an LFI's CDD/KYC controls are adequate and effective include:

- The LFI has a clear client acceptance policy, and it is followed.
- The LFI undertakes adequate CDD/KYC for individual customers and legal entity customers.
- The LFI undertakes the appropriate measures to understand the customer's ownership and control structure and identify and verify the identity of the customer's beneficial owners.
- The LFI has appropriate measures to understand the purpose of the business relationship and nature of a customer's business.
- The LFI applies CDD/KYC measures not just prior to beginning any business relationships but on an ongoing basis, where appropriate.
- The LFI has a proper process to screen customers at onboarding and on an ongoing basis for sanctions and adverse media.
- The LFI undertakes adequate specialize due diligence and EDD for high-risk customers (such as for PEPs, correspondent banking relationships, etc.).

3.2.3.3. Internal Controls

Mitigating measures related to internal controls entail policies, procedures, and processes designed to limit and control risks associated with core operational elements of the LFI's AML/CFT/CPF program and achieve compliance with relevant laws and regulations. In addition to policies and procedures, effective internal controls also encompass technological systems that an LFI uses to identify, assess, and manage compliance risks, including the LFI's approach to suspicious activity monitoring, investigation, and reporting; other reporting and information sharing; recordkeeping and record retention; and risk assessment.

- The suspicious activity monitoring program helps the LFI validate its risk assessment on a client-by-client and institution-wide basis to inform the suspicious activity reporting program;
- Suspicious activity reports and information sharing provide valuable leads to law enforcement agencies and help shape investigative priorities and inform prosecutions; and
- The recordkeeping and record retention obligations require documentation and trail of information to evidence the investigation conducted by LFIs which led to the regulatory reporting. LFIs should evaluate whether records are complete, accurate, and readily accessible for the required retention period. This includes checking that records support the investigation and reporting of suspicious activities and are compliant with regulatory requirements.

Overall, the policies, procedures, and processes that comprise the LFI's system of internal controls also have implications for the institution's organizational structure, including staff to ensure appropriate allocation of resources to appropriately address risks and ensure effective implementation of controls. In addition to baseline internal controls that apply to all operations, LFIs are expected to apply specific and enhanced monitoring to higher-risk areas.

Considerations to determine whether an LFI's internal controls are adequate and effective include:

- The LFI maintains consistent and complete customer data in relevant systems and has a sufficient alert workflow to manage and close/escalate the alerts.
- The LFI monitors all business relationships (including employee accounts) on an adequate basis with a monitoring system/process that is up to date and adequately designed to detect ML/TF/PF transactions and activity in line with the LFI's ML/TF/PF risk assessment and business.
- The LFI has an adequate process in place to report suspicious transactions and activity to the Financial Intelligence Unit and to decide whether an investigated account should be maintained, closed or subject to further monitoring.
- The LFI effectively implements its sanctions screening regime in accordance with regulatory requirements, such that the sanctions screening regime is configured to detect and manage the specific sanctions risks to which the LFI is exposed and is calibrated to the size, nature, and complexity of the LFI.
- The LFI implements Targeted Financial Sanctions ("TFS") during: (i) alert screening at customer onboarding and throughout the business relationship; and (ii) payment screening.
- The LFI maintains all customer records such that transactions recorded in the customer's account can evidence the investigation conducted by LFIs which led to the regulatory reporting.

3.2.3.4. Training

Global standards consistently emphasize the need for an enterprise-wide AML/CFT/CPF training program for all appropriate personnel within an LFI. Comprehensive mitigating measures related to training are critical to the overall effectiveness of an AML/CFT/CPF compliance program. Training should be provided on an ongoing basis and include changes to regulations, internal policies or procedures, and an understanding of evolving AML/CFT/CPF risks to which the LFI is exposed.

At a minimum, a comprehensive AML/CFT/CPF training program should ensure that:

- All new employees receive the LFI's required AML/CFT/CPF training within a specified time from their onboarding date;
- All staff within an LFI receive AML/CFT/CPF awareness training at least annually;
- The LFI provides targeted and role-based training to employees in the relevant compliance functions;
- The LFI provides targeted and role-based training to front-line staff with heightened exposure to AML/CFT/CPF risk;
- The LFI provides AML/CFT/CPF training an ongoing basis to the third line of defense; and

- The LFI provides AML/CFT/CPF training to the LFI's board of directors and senior management.

Considerations to determine whether an LFI's training controls are adequate and effective include:

- The LFI provides compulsory AML/CFT/CPF induction training and ongoing refresher AML/CFT/CPF training to all staff, including the Board of Directors and senior management;
- The LFI provides certain specialized and role-based training programs for relevant staff with AML/CFT/CPF responsibilities (e.g., TBML and PF awareness training for teams facilitating trade-finance).
- The LFI maintains training attendance and assessment records, and follows up on employees who repeatedly do not attend or fail trainings
- AML/CFT/CPF trainings are customized to the LFI's risk and the nature of its operations, including local regulatory requirements.

3.2.3.5. Independent Testing

Independent Testing is a risk-based, objective evaluation of the overall strength and quality of an LFI's AML/CFT/CPF program. Testing includes reviewing the LFI's policies, procedures, systems, and controls that mitigate and manage an LFI's ML/TF/PF risks and identifying any areas of the compliance program that may require remediation or improvement. Best practices suggest periodic testing of the AML/CFT/CPF program every 12-18 months or in light of significant changes to the LFI's risk profile, policies, procedures, systems, controls, or compliance staff. Although many LFIs have internal audit departments that execute independent testing, outside auditors, consultants, or other qualified independent parties can also conduct independent testing and/or audits.

Institutions should take steps to ensure the autonomy of the independent testing function by separating the resources dedicated to testing from those that create the policies, procedures, systems, and controls subject to testing. For LFIs that use external auditors or consultants for independent testing, the audit/independent testing program should ensure that there is no conflict of interest between the external auditors and the LFI. Conflicts of interest may include external auditors providing additional services such as training or helping the LFI develop and implement its compliance policies, procedures, systems, and controls.

At a minimum, a comprehensive audit/independent testing program should assess:

- The overall integrity and effectiveness of the institution's AML/CFT/CPF program, including policies, procedures, and processes;
- The LFI's risk assessment for reasonableness given the LFI's risk profile;
- The LFI's adherence to global standards regarding identifying, investigating, and reporting different types of suspicious transactions and maintaining relevant records;
- Management's efforts to resolve violations and deficiencies identified in previously conducted independent testing and audit reports; and

- The integrity and accuracy of the LFI's information technology systems and automated programs used to identify suspicious transactions and possible sanctions hits to satisfy AML/CFT/CPF compliance requirements.

The findings identified in the independent testing of the AML/CFT/CPF program should be promptly provided to the LFI's Board of Directors or owners/partners/shareholders in a comprehensive audit report. The audit report should contain the methodology of the independent testing and mention any violations; inconsistencies between policy, procedures, and processes and the way they are applied; and any other program deficiencies found during the assessment. Most importantly, the comprehensive report should assist the LFI's Board of Directors, owners/partners/shareholders, and senior management in identifying, prioritizing, implementing, and tracking corrective actions meant to address these deficiencies.

Considerations to determine whether an LFI's independent testing controls are adequate and effective include:

- The LFI has established an effective audit function which is independent of all operations.
- The audit function is appropriately staffed and organised.
- The audit function has the requisite competencies and experience to carry out its responsibilities effectively, commensurate with the LFI's ML/TF/PF risks.
- The audit function performs periodic inspections, and testing covers all aspects of the LFI's AML/CFT/CPF compliance program, which is supported with a comprehensive methodology and testing plan.
- The LFI's audit plan and audit report have been approved by the LFI's Board of Directors, Board-designated committee, or owners/partners/shareholders.

Quantifying Control Effectiveness

To quantify control effectiveness, an LFI should consider applying the following steps:

1. **Identify Key Controls**: LFIs should list all relevant controls that have been implemented to mitigate identified risks. These controls may include CDD/KYC procedures, transaction monitoring systems, employee training programs, and compliance auditing mechanisms.

2. **Define Effectiveness Criteria**: LFIs should establish criteria to measure the effectiveness of each control. This can involve setting specific, measurable goals for each control, such as reduction in the number of flagged transactions that require no further action (decrease in false positives), or the speed and accuracy of identifying high-risk transactions or clients.

3. **Measure Performance Against Criteria**: LFIs should collect data on how each control performs against the established criteria. This can involve quantitative measures such as the number of STRs/SARs filed, the rate of compliance with CDD/KYC requirements, or qualitative assessments through internal audits and external reviews.

4. **Scoring System for Controls**: LFIs should develop a scoring system to rate the effectiveness of each control based on its performance. For example, you might score controls on a scale from 1 (ineffective) to 5 (highly effective) based on how well they meet the effectiveness criteria.

5. **Aggregate Control Scores**: LFIs should calculate an overall control effectiveness score by aggregating the scores of individual controls. This can be done through a weighted average if certain controls are deemed more critical than others based on your institution's risk profile.

6. **Adjust for Interdependencies**: LFIs should recognize that controls might be interdependent. The effectiveness of one control might enhance or depend on the effectiveness of another. Consider these relationships when evaluating overall effectiveness.

7. **Feedback and Improvement Cycle**: LFIs should use the results from the quantification exercise to identify areas where controls could be improved. LFIs should then implement feedback loops where control effectiveness data is regularly reviewed and used to adjust control mechanisms.

8. **Regular Updates and Reviews**: Control effectiveness should be an ongoing concern, with regular updates and reviews, to ensure that controls are adapting to evolving risks, regulatory changes, and operational requirements.

9. **Documentation and Reporting**: LFIs should keep detailed records of the evaluation process, results, and any subsequent actions taken to improve control effectiveness.

3.2.4. Determining Residual Risk

3.2.4.1. Approach

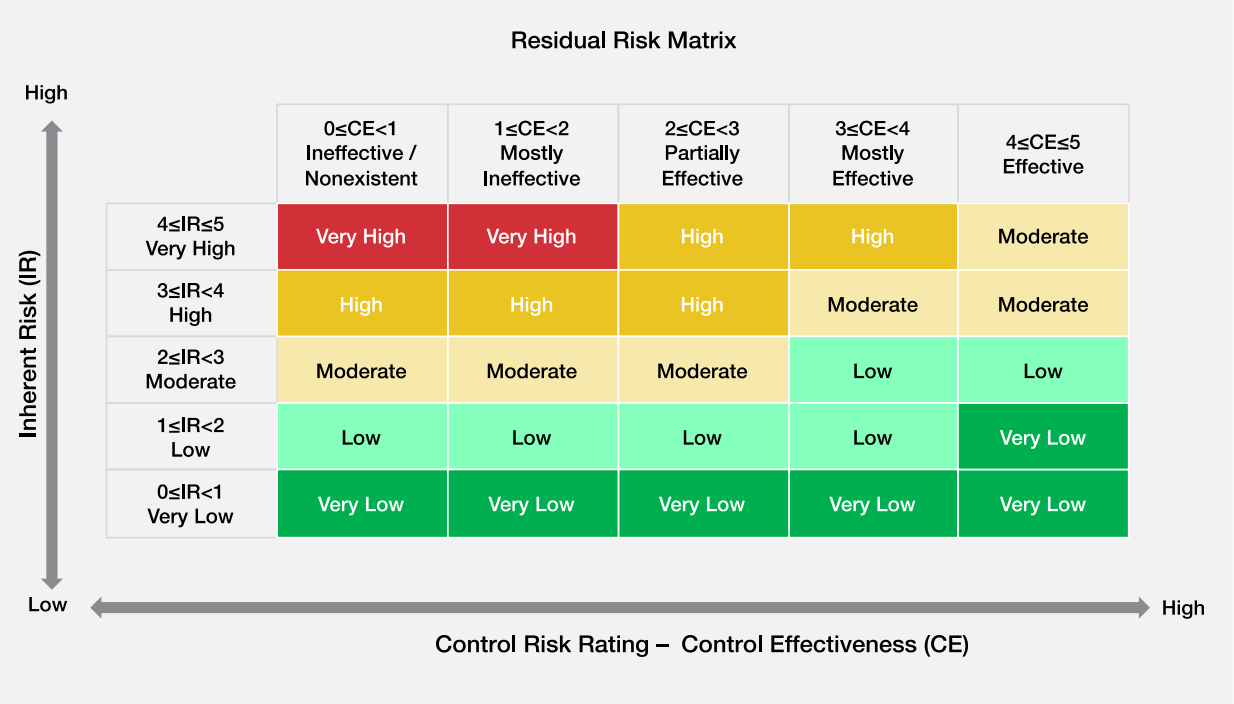
Once both the inherent risk and the design and effectiveness of an entity's mitigating controls have been considered, risk assessments should determine the entity's overall residual risk. Overall enterprise-wide residual risk is a function of the total inherent risk to which the LFI is exposed—through the customers,

geographies, products, services, delivery channels, transactions, and operational factors—and the extent to which its controls effectiveness limits the real risk that the inherent exposure will cause harm.

Determining residual risk is important to identify the nature and extent of ML/TF/PF risks so that an LFI's AML/CFT program can include tailored and effective risk mitigating measures, dedicating additional human, technological, and financial resources to the areas of the entity's highest risk. To that end, the outputs and findings of an LFI's risk assessment should be reasonable, and wherever the results are different than expected, these discrepancies should be rationally explained. LFIs should also retain previous versions of risk assessments to quickly and succinctly demonstrate to regulators or third-party assessors how the LFI's risk environment, related mitigating controls/measures, and residual risk have evolved over time. Senior management and the Board of Directors or owners/partners/shareholders can also reference previous versions when considering the LFI's risk appetite.

3.2.4.2. Residual Risk Matrix

A common practice for determining overall residual risk is the utilization of a residual risk matrix that aligns inherent risk and mitigating controls ratings or scores to generate a residual risk rating or score along a standardized assessment scale. Below is a sample residual risk matrix that utilizes a five-level scale for assessing inherent risks, mitigating controls, and the resulting residual risks. The below graphic is one example of a matrix that an LFI could leverage, and it is not meant to be mandatory or definitive. If an LFI, in the process of conducting its risk assessment, concludes a different risk rating matrix is more suited to its operating environment, an LFI should develop a risk rating matrix, which meets the minimum regulatory standards. The process for developing the risk rating matrix and rationale behind such a process should be clearly and thoroughly documented in an LFI's risk assessment methodology.



4. Application of an RBA

Once the LFI has identified and assessed the ML/TF/PF risks it faces, an LFI's Board of Directors, owners/partners/shareholders, or senior management should revisit the LFI's risk appetite statement to ensure it adequately reflects an institution's ML/TF/PF risk. The LFI's Board of Directors, owners/partners/shareholders or senior management should also assess whether they would like to lower the LFI's residual risk exposure by developing or updating AML/CFT/CPF controls and/or reducing exposure to inherent risks that cannot be managed effectively.

Based on this understanding, the LFI should develop a detailed action plan for the Board of Directors or owners/partners/shareholders that outlines new or updated AML/CFT/CPF controls for addressing inherent risks identified in the ML/TF/PF risk assessment and includes an estimated timeline of implementation. This action plan should take into account an RBA, such that if an LFI's residual risk increases, for instance, revealing that an LFI faces higher ML/TF/PF risks, the LFI may seek to develop enhanced measures to mitigate such higher risk by expanding the range, degree, frequency, and intensity of its AML/CFT/CPF controls. If possible, LFIs should consider leveraging advanced technology and data analytics to enhance its controls and measures. LFIs should clearly define the roles and responsibilities of different parts of the business in developing and executing changes to AML/CFT/CPF controls. Development and execution of changes to an LFI's AML/CFT/CPF controls may be tasked to different parts of an LFI's business, but the MLRO/Compliance Officer should maintain oversight and undertake coordination of these efforts. LFIs should prioritize controls and measures implementation based on where the assessment identified program gaps and deficiencies with increased levels of residual risk.

In accordance with an RBA, LFIs should mitigate identified risks through the implementation and updating of controls and measures tailored to these risks, such as:

- CDD/KYC processes, including customer and beneficial ownership identification and verification and developing an understanding the nature and intended purpose of the business relationship to establish a customer risk profile;
- EDD measures in higher-risk scenarios to obtain additional information on the customer and ensure enhanced ongoing monitoring and oversight of the customer relationship;
- Ongoing CDD monitoring to maintain current, accurate, and complete customer information and identify changes to the customer risk profile, which includes a risk-based frequency of sanctions and negative news screening of customers as well as routine transaction monitoring to develop averages of values/volumes transacted;
- Transaction monitoring controls and measures that detect and alert the LFI when customers have transactions based on the size, frequency, or patterns that may indicate unusual or potentially suspicious activity as well as activity that may be inconsistent with a customer's risk profile and/or history;
- Sanctions screening controls and measures for screening customers and transactions against relevant lists (e.g., the UN Consolidated List and the Local Terrorist Lists), reviewing potential sanctions matches, and escalating and reporting true sanctions hits;

- Suspicious activity monitoring systems and processes that are aligned to the institution's ML/TF/PF risk assessment and tailored to individual customer risk profiles, together with effective processes for reporting suspicious transactions or activity;
- Appropriate governance arrangements under which responsibility for AML/CFT/CPF is clearly allocated and senior leadership is closely involved in developing and implementing the RBA across the institution;
- Processes to recruit and vet staff in line with the institution's level and type of ML/TF/PF risk, to incentivize the advancement of compliance objectives, and to monitor the integrity of staff;
- Ongoing and role-based training for AML/CFT/CPF staff on the institution's business activities, risks, regulatory obligations, and policies and procedures;
- Controls to test the overall effectiveness of the institution's AML/CFT/CPF policies, procedures, and processes, including independent testing or auditing of the design and implementation of the institution's AML/CFT framework.

An effective RBA will help LFIs to address emerging risks and potential gaps or weaknesses in the AML/CFT/CPF framework that can be mitigated by introducing additional risk mitigation controls (new IT systems, supplemental job aids and desktop procedures, additional ML/TF/PF trainings on a particular topics, etc.), deploying additional resources (such as resources to support with CDD/KYC backlogs and late regulatory filings), and/or reducing exposure to inherent risks that cannot be managed effectively, as appropriate.

5. Conclusion

An ML/TF/PF risk assessment provides a snapshot of an LFI's ML/TF/PF risks and highlights gaps or weaknesses in an LFI's AML/CFT/CPF control environment. It is important that risk assessment findings are shared with an LFI's business lines, senior management, and Board of Directors, Board-designated committee, or owners/partners/shareholders, including other relevant stakeholders involved in the risk assessment process. Such stakeholders should be informed about the LFI's residual risk and on whether the risk assessment findings have changed or remained the same. Additionally, LFIs may wish to conduct a comparative analysis between the most recently conducted risk assessment and the one that preceded it, in order to keep a record of how the LFI has addressed it's AML/CFT/CPF program gaps and deficiencies over time.

Once an LFI has updated AML/CFT/CPF controls and based on the findings of the ML/TF/PF risk assessment, the LFI should review and test any new or revised controls. Such testing—whether conducted internally or by an independent third party—should be completed before the LFI's next risk assessment in order for the LFI to properly assess whether gaps from the risk assessment are addressed and aligned with the LFI's risk appetite. Findings from an LFI's risk assessment will also inform an LFI's business strategy, spanning customer exit decisions, monitoring and testing plans, and management information system data collected across an LFI. As such, LFIs should implement a robust ML/TF/PF risk assessment and pay particular attention to high-risk areas identified in the ML/TF/PF risk assessment in order to target the LFI's human, technological, and financial resources more effectively.

6. Annexure 1: Synopsis of the Best Practice

Introduction	**Purpose and Scope of the Best Practices**	The purpose of this Best Practices document is to assist the understanding and effective performance by the United Arab Emirates Central Bank's ("CBUAE") LFIs of their statutory obligations under the legal and regulatory framework in force in the UAE, of developing a risk assessment methodology, conducting a risk-based institutional risk assessment, and implementing a risk-based approach.
	Applicability	This Best Practices applies to all natural and legal persons, which are Financial Institutions or Licensees, or any other defined term which brings all entities within the scope of licensed and/or supervised entities by the CBUAE, in the following categories: national banks, branches of foreign banks, exchange houses, finance companies, payment service providers, virtual asset service providers, registered hawala providers; and insurance and re-insurance companies, agencies, and brokers.
	Legal Basis	• Federal Decree Law No. 20 of 2018 on Anti-Money Laundering and Combating the Financing of Terrorism and Illegal Organizations as amended. • Cabinet Decision No. (10) of 2019 concerning the Implementing Regulation of Federal Decree Law No. 20 of 2018 on Anti-Money Laundering and Combating the Financing of Terrorism and Illegal Organizations, as amended by Cabinet Decision 24 of 2022 ("AML-CFT Decision") and its amendments. • Anti-Money Laundering and Combating the Financing of Terrorism and Illegal Organisations Guidelines for Financial Institutions of July 2023.
	Definitions and Acronyms	• Several frequently used terms and phrase are defined, and a list of acronyms used in the Best Practices is provided.

Conducting a Risk-Based Institutional Risk Assessment	**Definition and Overview**	•This section details that a risk assessment consists of identifying an institution's inherent ML/TF/PF risks based on the LFI's specific characteristics, business model, and activities; reviewing the design and operational effectiveness of an LFI's control framework to manage these risks; and determining the residual risk that remains after an LFI's controls are applied to its inherent risk. •A broad example is provided of what risk assessments may look like for smaller, less complex institutions versus larger, more complex institutions. •This section also provides several examples of how LFIs can leverage the results of a risk assessment (e.g., developing an accurate risk appetite statement). •This section describes the granularity expected in a risk assessment, the relevant stakeholders in the risk assessment, and the frequency with which LFIs should conduct risk assessments.
	Principles and Best Practices for ML/TF/PF Institutional Risk Assessments	•This section outlines the three steps of a risk assessment: Measuring Inherent Risk; Assessing the Control Environment; Assessing Residual Risk. •General best practices are discussed, such as data quality and documentation. •There is extensive discussion and examples of an LFI assessing the inherent risk related to its customers, products, services, delivery channels, and geographies. A stand-alone text box and graphic provide aids for LFIs in conceptualizing inherent risk measurement. •There is discussion of assessing control effectiveness as it relates to an LFI's five-pillar AML program, including what should be included in the program and what supervisors may look for in an adequate program. •Finally, the section provides guidance on the approach for assessing residual risk and a graphic to aid LFIs in quantitatively measuring residual risk.
Application of an RBA	**Application of an RBA**	•This section notes that once a risk assessment is complete, the board of directors/senior management should revisit the LFI's risk appetite statement to ensure it adequately reflects an institution's ML/TF/PF risk as well as if the LFI needs to develop or update AML/CFT/CPF controls as a result of the assessment. •Several examples of how controls and measures could be updated are provided. •This section also encourages an LFI to develop a detailed action plan for the implementation or update of AML/CFT/CPF controls and that the MLRO should own the plan.